Examensarbete inom integrerad produktutveckling

Grundnivå, 15 hp

Skydd och incidentrespons inom IT-säkerhet

En studie kring utvecklingen av ransomware

CHRISTOFFER ERICSON

NICK DEREK

Stockholm, Sverige 2023

KTH Industriell teknik och management

Examensarbete Integrerad produktutveckling grundnivå, 15 hp, kurskod MF131x

Skydd och incidentrespons inom IT-säkerhet: En studie kring utvecklingen av ransomware

Christoffer Ericson
Nick Derek

Examinator	Handledare
Sofia Ritzén	Magnus Eneberg och Gunilla Ölundh Sandström

Sammanfattning

Cybersäkerhet är ett konstant växande hot mot organisationer, genom det ständigt ökade digitaliserade samhället, dock finns tecken på att medvetenheten hos organisationer ökar vad gäller cyberattacker och cybersäkerhet. Cyberattacker kan skapa konsekvenser som kan förhindra organisationens verksamhet. Detta lägger grunden till arbetet, att se hur försvarsförmågan har utvecklats. I värsta fall medför en cyberattack konsekvenser som kan äventyra en organisations överlevnadsförmåga. I och med det nya hotet ransomware, där hotaktören krypterar offrets filer och sedan kräver en lösensumma, har konsekvenserna kraftigt kommit att bli mer fatala. Metoderna för ransomware utvecklas av hotaktörerna vilket kan bidra till mer än bara ekonomiska konsekvenser för organisationen. Mot ransomware gäller i stort samma skyddsåtgärder som mot alla former av cyberattacker, däremot finns en del särskilt viktiga aspekter som belyses i detta arbete, till exempel implementering av backups, adekvat dataskydd samt god Patch Management (d.v.s. protokoll för att åtgärda sårbarheter i programvara). I arbetet sammanställs en branschkonsensus för hur organisationer skall arbeta gentemot cyberattacker, specifikt ransomwareattacker. Detta har gjorts genom en litteratur- och kvalitativ intervjustudie, som sedan har analyserats och diskuterats. Intervjustudien har genomförts hos organisationer som bedöms lämpliga för detta då de dagligen arbetar med cybersäkerhet. En av rekommendationerna är att ha en bra backuprutin, där man skapar, distribuerar och testar dessa. Genom arbetet belyses även hur god patch management bör implementeras. Slutligen presenteras även en ny metod, Ransomware 3.0 där hotaktörer stjäl en organisations IT-miljö för att sedan radera denna lokalt hos organisationen och sedan säljer tillbaka denna, som används av hotaktörerna, som hittills varit okänd, där vidare forskning bör vidtas.

Nyckelord:

IT-säkerhet, Cybersäkerhet, Datasäkerhet, IT-angrepp, Cyberattack, Dataläcka, Ransomware, Backup, Kryptering, Patch Management, Riskhantering, Incidentrespons, Regelefterlevnad.

KTH Industrial Engineering and Management

Degree project in Integrated Product Development
First cycle, 15 cr, course code MF131x

Protection and incident response within IT-security: A study about the development of ransomware

Christoffer Ericson
Nick Derek

Examiner	Supervisor
Sofia Ritzén	Magnus Eneberg and Gunilla Ölundh Sandström

Abstract

Cybersecurity is a constantly growing threat against organisations due to the increasingly digitalisation of society, although there are signs that the consciousness at organisations has increased regarding cyberattacks and cybersecurity. Cyberattacks can create consequences that can restrain an organisations operations. This creates the foundation for this study, to see how the defence capabilities has developed. A cyberattack can, in the worst case scenario, threaten an organisations ability to survive. In regards to the new threat, ransomware, where the threat actor encrypts the victim's files and demands a ransom, the consequences can be fatal. The new methods associated with ransomware, where the threat actor also exfiltrates the victim's files, strongly impact the organisations ability to operate. This could lead to economic consequences, as well as damages towards stakeholder relations. Most protective measures applies towards ransomware, however there are some especially important aspects that are presented in this paper, such as implementation of backups, sufficient data protection as well as good Patch Management (protocol to patch vulnerabilities in software). In this paper, an industry consensus on how organisations should work against cyberattacks, especially ransomware, is compiled. This was performed through a litterature and a qualitative interview study. Both studies has been analysed and discussed. The interview study has been accomplished by interviewing appropriate organisations that work with cyber security daily. One of the recommendations is to have a good backup protocol, which implies creating, distributing and testing these backups. This paper also presents how a good patch management should be implemented. Finally, this paper presents a new method, Ransomware 3.0 where the threat actor steals an organisations IT environment, and then destroys the local copy at the organisation to then sell it back, that is used by the threat actors, that is still uncommon knowledge, where continued research have to be conducted.

Keywords:
IT-security, Cyber Security, Data Security, IT Attack, Cyber Attack, Data Exfiltration, Ransomware, Backup, Encryption, Patch Management, Risk Management, Incident Response, Compliance.

Förord

Detta kandidatexamensarbete har utförts på Kungliga Tekniska högskolan inom ämnesområdet Integrerad Produktutvekling. Genom studien behandlar vi den rådande IT-säkerhetsfrågan angående Ransomware som har kommit att bli den trendande angreppsmetodiken.

Vi vill rikta ett stort tack till Jerry Illikainen och Claes Törneman vid Säkerhetskontoret som har bidragit på ett vitalt sätt med teknisk sakkunnighet, handledning samt bidragande till empirisk data.

Vi vill även tacka Gunilla Öhlund Sandström vid Kungliga Tekniska högskolan som har gjort detta arbetet möjligt att genomföra, samt tacka för hennes förtroende för oss. Vi tackar för din uppmuntran och ditt intresse genom detta arbete.

Vi tackar er för er stöttning och stora intresse genom arbetet.

Nick Derek och Christoffer Ericson
Stockholm, Juni 2023

Nomenklatur

Beteckning:	Avser:
Antivirusprogram	Avser mjukvara för att undvika virus
Attackyta & Attackvektor	De exponerade ytorna som kan utnyttjas
Backup	Säkerhetskopia
Binärer	Binär kod
Bruteforce	En metod för att knäcka lösenord
CDP	Continuous Data Protection
Chat Control	Föreslagen lagstiftning
CISO	Chief Information Security Officer
Databas	Datastruktur som används inom IT-miljöer för lagring av data
GDPR	General Data Protection Regulation
Hotaktör	De kriminella som opererar attacker
IT-infrastruktur	Avser hela IT-miljön
IoT	Internet of Things
Malware	Skadlig kod som distribueras för att angripa en enhet
MFA	Multi Factor Authentication
MS	Murphy Solution
NCSC	(Sv) Nationellt Cybersäkerhetscenter eller (UK) National Cyber Security Centre
NIST	National Institute of Standards and Technology
NOC	Network Operations Center
Patchning & Patch Management	Att åtgärda mjukvarusårbarheter
Pentest	Metod för att testa ett system för svagheter
Phising	Nätfiske
PS	Partnersec

RDP	Remote Desktop Protocol, protokoll för fjärrstyrning av enhet
RaaS	Ransomware as a Service
Red Team	Pentestare som iscensatt opererar som hotaktörer
SK	Säkerhetskontoret
SIC	Security Intelligence Operation
SOC	Security Operations Center
SSH	Secure Shell
Supply Chain Attack	Attack som avser skada en underleverantör till offren
Sårbarhet	Svaghet som kan utnyttjas
TS	Truesec
VPN	Virtual Private Network

Innehållsförteckning

1. Inledning **1**
1.1. Problematisering 1
1.2. Syfte 3
1.3. Forskningsfrågor 3
2. Teori **4**
2.1. Backup 5
2.2. Incidentrespons & riskhantering 7
2.2.1. Identifiera 7
2.2.2. Skydda 8
2.2.3. Upptäcka 10
2.2.4. Respons 11
2.2.5. Återhämta 12
2.3. Kryptering 13
2.3.1. Symmetrisk kryptering 14
2.3.2. Asymmetrisk kryptering 15
2.4. Hashfunktioner 16
2.5. Regelefterlevnad 17
2.5.1. Chat Control 17
2.5.2. GDPR och övrig regelefterlevnad 18
2.6. Ransomware as a Service 19
3. Metod **20**
3.1. Teoretisk referensram 20
3.2. Tillvägagångssätt 20
3.3. Beskrivning av organisationer 21
3.3.1. Säkerhetskontoret 21
3.3.2. PartnerSec 22
3.3.3. Truesec 22
3.3.4. Murphy Solution 23
3.4. Urval av organisationer och respondenter 23
3.5. Analys av empirisk data 24
3.6. Kvalitetsmått 24
4. Empiri & resultat **26**
4.1. Ransomware 3.0 26
4.2. Kryptovaluta 26
4.3. GDPR & regelefterlevnad 28
4.4. Patch management 30
4.5. Dataskydd 32
4.6. Implementering av backup 35
4.7. Konstant övervakning 38
4.8. Ransomware as a Service & ekonomisk affär 40
5. Analys & diskussion **44**

5.1. Ransomware 3.0 ... 44
5.2. Kryptovaluta ... 44
5.3. GDPR & regelefterlevnad ... 45
5.4. Patch management ... 46
5.5. Dataskydd ... 47
5.6. Implementering av backups ... 49
5.7. Konstant övervakning ... 51
5.8. Ransomware as a Service & ekonomisk affär ... 53
6. Slutsats & rekommendationer ... 54
6.1. Akademiskt bidrag ... 55
6.2. Rekommendationer till organisationer ... 56
Referenslista ... 58
Bilagor ... 63
Bilaga 1. Intervjuguide ... 63
Bilaga 2. Ändringsmanus ... 65

1. Inledning

1.1. Problematisering

Dagens digitalisering medför hot för dataintrång för alla IT-system som är uppkopplade till internet (Chen och Abu-Nimeh, 2011). Detta gäller självklart privatpersoner, men när datainnehållet är av sådan vikt att det rör nationell säkerhet blir känsligheten mot intrång signifikant högre. Trots att utvecklingen inom cybersäkerhet minskar påverkan från de tusentals nya, så kallade, malwares kan nya banbrytande malware ändra scenen för cybersäkerhet.

Dataintrång är ett återkommande problem och det är i dagsläget en praktisk omöjlighet att förbereda och avvisa dessa intrång till fullo (Alieksieieva och Dmytruk, 2017). Därför har man en process som först identifierar incidenten, för att efter identifiering kunna använda de verktyg som är bäst anpassade mot just den typen av intrång. Skribenterna menar att oavsett hur mycket man förbereder sig - och oavsett vilka skydd man har - kommer risken för intrång finnas och att denna risk beror på komplexiteten och mångfalden i organisationen. De nämner, precis som Chen och Abu-Nimeh (2011), även risken för nya hot, där okunksap om attackvektorer samt signaturelement för attacken finns.

Ett försök till att förbättra skyddet mot virus gjordes av Murali och Shunmuga Velayutham (2020). I försöket studerades hur mutationer på ett virus (“Timid”), gjorda av evolutionära algoritmer, hindrade vanliga antivirusprogram att upptäcka varianterna. I studiens resultat är det tydligt att evolutionen av ett modervirus hindrar antivirusprogram att upptäcka viruset. En stor del av moderviruset behöver endast genomgå ett fåtal förändringar (t. ex obfuskera binärer) innan antalet antivirusprogram som upptäckte dem minskade signifikant. Efter enbart sex generationer av utveckling upptäcktes 15 av 20 virus av tre eller färre antivirusprogram. Studien gjordes med hjälp av en databas på över 60 av de mest använda antivirusprogrammen.

Till skillnad från den tidigare nämnda studien, där skribenterna själva matade in viruset, finns det olika sätt att initiera ett virus till ett system. I en rapport av Maiorca, Biggio och Giacinto (2020) beskrivs det som kallas för attackyta, *“With this term, we define non-executable files whose aim is exploiting vulnerabilities of third-party applications to trigger download (or direct execution) of executable payloads.”* Attackytor uppstår

framförallt vid processering av data som tillhandahålls av potentiella attackerare -- exempel vid processering av bilder, PDF-filer, Word-dokument och dylikt. Dessutom är den tredje partens program - ofta - inte tillräckligt uppdaterade utifrrån avseendet dataintrång.

Ransomware är en typ av IT-angrepp med viss särskild karaktär. Gemensamt för ransomwareattacker är att syftet med dem är att på ett eller annat sätt göra den utsattes dator eller större IT-infrastruktur obrukbar - vanligtvis genom att angriparen krypterar den utsattes filer eller på annat sätt låser den utsatte ute från systemet - så att angriparen sedermera kan utkräva en lösesumma för att den angripne ska återfå kontroll över sitt system (CISA). Ransomware är ett förhållandevis nytt fenomen, åtminstone vad gäller hur och när denna typ av IT-attack kommersialiserades och systematiskt började riktas mot stora organisationer av väl sammansatta ransomwaregrupper. På bara drygt 10 år har ransomware kommit att bli en av de största riskerna för organisationer vars data lagras i olika IT-system då en enda ingång till offrets system skulle kunna ge angriparen full åtkomst till hela infrastrukturens data. Vanliga attackytor som har använts flitigt vid ransomware-attacker är (1) genom spridning av virus via epost, (2) via Remote Desktop Protocol (där man låter en dator fjärrstyra en annan) samt (3) via sårbarheter i brett distribuerad mjukvara. Ett alternativt sätt att hantera ransomware-attacker är att återgå till en tidigare version av organisationens arbete med hjälp av backup:s. Detta innebär att organisationen har säkerhetskopierat sitt tidigare arbete och ställer om sin hårdvara till denna fas, för att på så sätt undvika att betala lösesumman. (Furnell och Emm, 2017)

IT-säkerhetsbranschen kan liknas vid en lek mellan katt och råtta. Hoten som skapas av hotaktörer skapas på grund av det IT-system de vill erövra eller förgöra och det är generellt CISO:s ansvar att se till att organisationen är förmögen att terminera intrång. Det är svårt att förbereda och hindra attacker innan de sker eftersom hotaktörna är tvungna att ta sig in via vägar som inte har det nödvändiga skyddet eller övervakningen. Detta ökar behovet av sakkunnig kompetens i responshantering. Att utveckling sker är nästintill uppenbart då denna utveckling sker reaktivt mot attacker och är alltså inte en form av produktinnovation, utan en nödvändig utveckling för samhällets fortsatta tillväxt, både ekonomiskt och socialt, pådrivet av den specifika föregående IT-attacken.

1.2. Syfte

Syftet med detta arbete är att undersöka hur försvarsförmågan för organisationer har utvecklats, samt varför den har utvecklats. Vidare vill vi utreda vad de bästa metoderna är för att undgå ett cyberangrepp - specifikt ett ransomwareangrepp.

1.3. Forskningsfrågor

De frågor som framförallt skall besvaras i detta arbete är:

1. Hur har synsättet på IT-säkerhet utifrån ett organisatoriskt perspektiv förändrats under den senaste tiden?
2. Vilken typ av skydd finns för att undgå den slutliga krypteringen vid en ransomwareattack?
3. Hur implementeras backup:s och finns det potentiell problematik kring tillämpningen av sådana?

2. Teori

Utvecklingen av IT-system är kontinuerlig och nya innovativa sätt att attackera samt skydda ett IT-system uppkommer regelbundet. Detta medför att den teoretiska bakgrunden för detta arbete bör läsas kritiskt och eftertänksamt. Vetenskapliga publikationer som är publicerade kan, och kommer med stor sannolikhet att, vara utdaterade vid skrivandets stund. Den teori som beskrivs i följande kapitel antas vara en grundläggande bakgrund och inte ett nuvarande vetenskapsläge, där branschen utvecklas i realtid med nya hotaktörer och attackmetoder ständigt, och där branschen som helhet kommer att ligga före akademin. För detta arbetets relevans kommer publicerad information från branschen och dess organisationer och myndigheter att väga tyngre än det akademiska ditot, p.g.a. inneboende tröghetseffekter.

Ransomware är ett relativt nytt, men starkt växande problem för både organisationer och myndigheter (Min *et al.*, 2022). Angriparen krypterar vanligtvis användarens filer, skriver om dessa och kräver en lösesumma för att denne ska återfå tillgång till dem igen. Denna typ av attack kan skapa stora kostnader för offret genom att hotaktören ofta kräver stor betalning för dekryptering av offrets data. Det är även tänkbart att hotaktören kan komma att kräva betalning för förstörelse av den extraherade datan (Cluley, 2021), så kallad dubbelutpressning. Även om det finns möjligheter att upptäcka och skydda sig mot denna form av cyberbrottslighet kan softistikerade, intelligenta och målinriktade attacker och malware kompromettera systemet helt oupptäckt. *"However, it is difficult to detect ransomware when its behavior has not been observed."* - Min *et al.*, (2022).

Furnell och Emm (2017) förklarar det totala skyddet mot ransomware med hjälp av modellen ABC som bäst förklaras på engelska, Anti-malware, Backup och Critical patching. De menar att det första steget som tas för att skydda sig mot en ransomwareattack, eller andra närbesläktade dataintrång, är att ha ett uppdaterat och effektivt anti-malwareprogram, mer känt som antivirusprogram. Det andra steget är att ha ett backup på organisationens IT-system. Dock förekommer ofta problem med dessa backup:s, då faktorer såsom hur och var dessa lagras (lokalt eller remote t. ex), då de även har en risk att bli krypterade eller i annan mening förstörda av en hotaktör. Författarna stärker även nyttigheten av att kontrollera vilka användare som har vilka rättigheter och kontinuerligt uppdatera dessa för att utveckla och förbättra organisationens säkerhet ytterligare.

Ransomware-attacker har under de senaste åren ökat markant till antalet. Från 2005 till 2016 rapporterades 7600 attacker, men även ransomwareattacker som andel av de totala dataintrången har ökat till en majoritet (Yacoob *et al.*, 2017). Denna ökning beror på olika former av attackvektorer, där Schwartz (2020) menar på att de mest förekommande attackvektorerna är RDP och Phishing, medan Yacoob *et al.* (2017) menar att ökandet av IoT-enheter expanderar och exploaterar attackvektorerna ytterligare. Det har även blivit enklare för angripare att ta emot lösesummor via det växande fenomenet kryptovaluta. Exempel på sådana valutor är Bitcoin och Ethereum där insyn i transaktionerna som sker är begränsad (Yacoob *et al.*, 2017). Den vanligaste valutan som används för betalning i samband med ransomware är Bitcoin, och för denna valuta används så kallade wallets. En wallet kan aldrig knytas direkt till en särskild innehavare utifrån valutans upplägg, men om ett offer betalar Bitcoin:s till en specifik wallet kan man på så sätt veta vilken angriparen just den wallet:en tillhör genom att kartlägga tidigare transaktioner till eller från den wallet:en. (Warmke, 2021). Detta kan vara till god nytta för att studera till vilken eller vilka wallet:s pengarna sedan slussas vidare till, då alla Bitcoin-transaktioner offentliggörs i nätverket för att signeras/valideras, samt vilka wallet-adresser pengarna skickats emellan. Detta skulle kunna leda till att man kan kartlägga hur och var pengarna från denna typ av cyberkriminalitet slussas.

2.1. Backup

För att undgå behovet av att erlägga en lösesumma till angriparen kan organisationer fördelaktigt använda sig av backup:s (Min *et al.*, 2022). Däremot kan även dessa säkerhetskopior vara offer för kryptering eller destruktion och därmed förbli helt obrukbara. Metoder och rutiner för hur backup:s skall användas för att återställa systemen är samtidigt vitalt för att undgå att helt hamna i händerna på hotaktören där den sista utvägen blir att betala den krävda lösesumman. Uppkomsten av Ransomware 2.0 (Li and Liao, 2020) innebär att hotaktören inte bara kan tänkas låsa ut användaren från dess data, utan även exfiltrerar datan för att kunna sälja den vidare till exempelvis konkurrenter eller andra fientliga aktörer. Detta innebär att enbart ett backup-system inte är en ensam lösning på problemet ransomware, men kan och kommer att mitigera riskbilden för organisationen. Det finns oftast aldrig några som helst säkra garantier på att angriparen faktiskt förstör ens data, utan man bör i regel anta att datan är äventyrad och har blivit exploaterad av andra än den primära hotaktören.

Att kontinuerligt skapa backup:s är en fundamental grund för en organisation, men det är också viktigt att verifiera att dessa backup:s kan återställas felfritt som i att de återställer alla filer och att de inte innehåller skadlig kod (Malecki, 2019). När dessa steg är genomförda bör en fysisk backup skapas, förslagsvis på en extern hårddisk som är offline (d.v.s. inte är uppkopplad till IT-miljön). Är backup:en sparad online (uppkopplad mot IT-miljön) finns risken att denna backup blir infekterad av den skadliga koden i händelse av penetrerad IT-miljö. Thomas och Galligher (2018) förtydligar detta genom att förklara begreppet CDP (Continuous Data Protection). CDP är en form av backup som sker direkt, d.v.s. sker en förändring lokalt kommer denna förändring även att ske i realtid där datat och backup:en finns lagrade, vare sig detta är lokalt på enheten eller någon annanstans inom IT-miljön eller tillhörande molntjänster. Detta medför att om en datafil blir krypterad lokalt kommer samma fil även bli krypterad där den är lagrad, vilket betyder att man inte nödvändigtvis kommer kunna återskapa filen lokalt. Däremot använder CDP en versionshantering, som möjliggör att användaren kan återgå till ett tidigare - icke-krypterat - tillstånd vilket innebär att det går att återskapa IT-miljön till en version som är läsbar.

Vid ett lyckat intrång är det generellt sätt inte den första skadliga mjukvaran som introduceras på offrets enhet som är den mjukvaran som sedermera kommer att kryptera användarens filsystem (Grimes, 2021). Det första programmet som installeras är ofta ett så kallat dropperprogram. Eftersom detta program inte exekverar någon skadlig kod per se är det lätt att denna förblir obemärkt. En dropper kan vänta i allt från veckor till månader innan den laddar ner ransomware:t som kommer att kryptera användarens filer. Detta medför att droppern kan följa med i återställningen av en backup, vilket kan skapa problem om den aktuella versionen är infekterad och backup:en behöver återskapas då denna dropper ligger kvar i IT-miljön. Detta leder till att processen itereras om på nytt, med samma sårbarheter.

Vid ett intrång, där organisationen valt att återställa en tidigare version av sin miljö, kan ett dropperprogram upprätta bakdörrar (alternativa redundanta ingångsvägar) som hotaktären kan utnyttja(Grimes, 2021). Detta innebär att trots att denna backup inte verkar exekvera skadlig kod så har hotaktören fortsatt inträde via dessa bakdörrar, där de på nytt kan infektera datorn och få tillgång till offrets filsystem och nätverk.

2.2. Incidentrespons & riskhantering

För att effektivt kunna svara på och analysera vad som sker i ens IT-miljö behöver organisationen säkerställa sin förmåga till övervakning(*Nationellt Cybersäkerhetscenter, NCSC*, 2022). Att övervaka sin miljö bör för en organisation vara lika naturligt som att ha inbrotts- eller brandlarm. Risken med att ha bristfällande övervakningsförmåga är exempelvis hänförlig till att hotaktörer kan dölja sin närvaro, att skadlig kod obemärkt exekveras eller att obehörig aktivitet fortgår. Miloslavskaya (2018) menar på att för att ha en välfungerande incidenthantering krävs det en *Security Intelligence Operation* (SIC) som besitter expertis och bedömingsförmåga kring vad som kan kopplas till fientligt uppsåt. Författaren antyder att för att kunna hantera ett dataintrång på ett korrekt sätt krävs det att det finns experter som har förmågan att snabbt identifiera obehörig aktivitet och kan skilja denna från organisationens legitima aktivitet.

Vid ett intrång då data eventuellt riskerar exploateras för antingen stöld eller kryptering behöver ett responsteam direkt bli meddelade för att minska de potentiella skadorna, samt för att förhindra att hotaktören eskalerar attacken ut i nätverket där fler enheter kan tänkas äventyras (Yacoob *et al.*, 2017). Teamets första och främsta uppgift är att koppla bort den utsatta enheten, förhindra eskalation av attacken genom att stoppa hotaktörens åtkomst till den övriga miljön och sedermera återskapa en backup om skada redan skett för att kunna fortsätta den operativa verksamheten. Även känsliga delar av - eller hela - nätverket bör skyndsamt isoleras och segmenteras för att minska risken för eskalering av angriparens tillvägagångsmetoder (Croke, 2020).

Riskhantering avseende IT-säkerhet handlar ändock om betydligt fler aspekter än bara incidentrespons, och enligt den amerikanska myndigheten NIST kan man dela upp säkerhetsarbetet i fem olika delar enligt deras ramverk *Cybersecurity Framework* (*National Institute of Standards and Technology, NIST*. April 2018) (Ross, Winstead and McEvilley, 2022):

2.2.1. Identifiera

I denna fas handlar det om att tydligt definiera organisationens viktigaste processer och immateriella tillgångar. Man kan exempelvis ställa sig frågan “vad måste fungera inom organisationen för att vi överhuvudtaget ska ha ett existensberättigande?”, och svaren på den frågan skulle exempelvis kunna vara att ett fungerande betalsystem måste finnas, att

kunddata ständigt måste hållas säkert, att intern kommunikation finns eller att organisationen kontinuerligt har tillgång till vital information för att kunna hålla igång sin verksamhet.

Det är även viktigt att tydligt ha en karta över vilken typ av data som lagras och var detta sker. Detta för att man ska ha god koll på var känslig data kan finnas i sin IT-miljö (*Nationellt Cybersäkerhetscenter, NCSC*, 2022). Även hård- och mjukvara behöver ständigt hållas inventerad eftersom dessa är ingångspunkter för en attack.

Slutligen behöver en organisation definiera vilka typer av risker man är utsatt för och vilken hotbild man står under (kan t. ex vara ekonomiska risker, konkurrensrisker, övervaknings-/integritetsrisker eller förstörande risker) för att sedermera kunna tillsätta adekvata protokoll, arbetsprocesser och ansvarsroller för att ständigt förbättra sin säkerhetsstandard (Häckel *et al.*, 2019).

2.2.2. Skydda

För att skydda sin infrastruktur är det viktigt att man för varje anställd har ett eget konto, med just precis nödvändig behörighetsnivå som den anställde i fråga har behov av för att utföra sitt arbete, då hotaktörer kan utnyttja användarens behörighet för att initiera skadlig kod (Chappell, 2013). Varje konto bör ha adekvata inloggningsmetoder, där *Multi Factor Authentication* (MFA) är ett minimumkrav för all typ av datatillgång för att säkerställa att kontot endast används av den korrekta användaren på ett behörigt sätt. Nationellt Cybersäkerhetscenter (2022) menar att adekvat funktion för detta är att säkerställa att MFA implementeras vid autentisering till internetexponerade miljöer (såsom RDP-, VPN-, SSH-anslutningar eller epostkonton), informationstillgångar av högt skyddsvärde eller till konton med sysadmin-behörighet.

Det är även viktigt att man har ständig och nära kontroll på de fysiska enheterna inom organisationen, så att de inte hamnar på vift eller utsätts för hårdvarubaserade angrepp eller att redundanta bakdörrar introduceras på annat sätt(Palanisamy, Norman och Mat Kiah, 2021). Att ha ett välfungerande protokoll är otroligt viktigt för att anställda ska fortsätta följa protokollet och inte frångå det. Vidare är det av stor vikt att man skyddar organisationens data. Detta kan göras genom att all kommunikation som sker är krypterad. Lagrad data bör också vara krypterad (*UK National Cyber Security Centre*, NCSC, 2022).

Det är även viktigt med adekvata protokoll för hur man genererar (och även rutiner för att spara) loggar, samt att signering av datat sker för att kunna säkerställa att endast behöriga ändringar av datat har förekommit(*UK National Cyber Security Centre*, NCSC, 2022). Data som inte längre är relevant för organisationen, bör av flera skäl raderas på ett säkert och fullständigt sätt. Här behöver organisationen ha tydliga riktlinjer för hur länge sparad data skall lagras, och hur den rent tekniskt skall förstöras när syftet med att lagra den upphör att gälla.

Att skydda sin data innebär även att man ständigt har som vana att göra backup:s av sitt system. För att mitigera riskerna hänförliga till ransomwareattacker bör flertalet backup:s lagras på skilda platser (inom och utom miljön), där minst en backup bör finnas sparad fysiskt frånkopplat från IT-miljön (Malecki, 2019).

En annan viktig aspekt är att det sällan räcker med så kallad svartlistning(*Nationellt Cybersäkerhetscenter*, NCSC, 2022). För att säkerställa goda rutiner krävs det att man vitlistar både hård- och mjukvara genom adekvata certifieringsprocesser. Det är viktigt att man endast låter genomgången vitlistad hårdvara finnas i nätverket, då icke-certifierad hårdvara klart utför en kritisk säkerhetsrisk utifrån att den direkt har åtkomst till IT-miljön. Det krävs även tydliga rutiner och vitlistning av hur och vilken mjukvara som får köras inom miljön då skadlig kod enkelt kan föras in i infrastrukturen om vilken mjukvara som helst tillåts att köras av miljöns användare. Helst skall endast utgivarsignerad och allmänt betrodd mjukvara vara vitlistad. För att säkerställa att en enskild anställd inte missbrukar detta bör all annan mjukvara än den vitlistade vara blockerad inom miljön.

Att bygga sin IT-miljö på ett segmenterat sätt är också en del av säker nätverkskonstruktion. Kritisk infrastruktur bör ligga isolerat från andra typer av miljöer (*Nationellt Cybersäkerhetscenter*, NCSC, 2022), och det är viktigt att ha rätt behörighetsnivåer på sådana delar av infrastrukturen som man själv inte tillhandahåller. En möjlig sårbarhet för en organisation är ens underleverantörer, via så kallade Supply Chain Attacks. Man behöver vidta korrekta protokoll och filtrering mellan denna segmentering av nätverken för att uppnå korrekt skyddsmekanism, där viss nätverkstrafik kanske aldrig någonsin skall exponeras för resterande nätverk medan annan nätverkstrafik kan tänkas tillåtas för att distribuera data mellan nätverken.

Det är även viktigt med korrekta protokoll inom infrastrukturen, där man jobbar med brandväggar och andra protokoll mellan olika enheter och anslutningar(*UK National Cyber Security Centre*, NCSC, 2022). Även andra end-point-lösningar såsom antivirusprogram på varje enskild end-point fyller en viktig funktion utifrån skalskyddets egenskaper. För att vidare skydda sig mot ett angrepp kan man utföra så kallade pentest, där inhyrda eller anställda IT-säkerhetsexperter försöker åstadkomma det som hotaktören försöker utan att förverkliga de skadliga konsekvenserna, men med samma metoder och tillvägagångssätt. Detta utförs ofta genom att pentestaren försöker skaffa sig åtkomst till IT-miljön utifrån och sedan eskalera angreppet genom att tillskansa sig erforderlig behörighet inom nätverket för att sedermera kunna skeppa in den payload som exekverar den skadliga koden som används för att uppnå målet med attacken.

Slutligen är det viktigt att varje anställd som har tillgång till organisationens IT-system har god vana, rutin och kännedom om hur man skyddar sina egna enheter och den gemensamma miljön (Palanisamy, Norman and Mat Kiah, 2021). Det är viktigt att man alltid håller enheterna fullt uppdaterade mot säkerhetshål, samt att de anställda är bekanta med riskerna och de vanligaste attackvektorerna. Om organisationen själv inte är förmögen att hantera dessa säkerhetsfrågor internt är det viktigt att man hyr in dessa tjänster av en MSP-aktör, där en SOC är en ofta förekommande tjänst för att uppfylla de kvaliteter som krävs för en säker IT-miljö.

2.2.3. Upptäcka

Här behöver man ständigt uppdatera sina sätt och rutiner för att identifiera eventuellt skadliga penetrationer av ens nätverk(Shekhtman och Waisbard, 2021). Detta sker genom att man iterativt uppdaterar de signaturelement med vilka man identifierar ett intrångsförsök. Det är även viktigt att onormala förändringar eller andra oegentligheter i ens nätverkstrafik eller kontohändelser sparas i så kallade loggar . Loggarna måste genereras och sparas enligt väl valda metoder, så att man inte riskerar stå utan fullständiga loggar en kort tid efter att man behöver utreda obehörig nätverksåtkomst rent forensiskt. En vital faktor för att kunna gå tillbaka i tiden och spåra misstänkt aktivitet är att användarkonton aldrig raderas, utan bara inaktiveras, så att specifik nätverksaktivitet hela tiden kan kopplas till ett konto. Att inaktivera men inte radera en uppsagd anställds konto ligger därav i organisationens egna

intresse och hanteringen bör företrädesvis förvaltas på ett - åtminstone delvis - automatiserat vis (*Nationellt Cybersäkerhetscenter*, NCSC, 2022).

Det är vidare viktigt att ha protokoll för att kunna övervaka att ens nätverkstrafik används på ett sätt som motsvarar förväntningarna på hur nätverkstrafiken regelmässigt opereras (*Nationellt Cybersäkerhetscenter*, NCSC, 2022). Om vissa databaser t. ex aldrig är exponerade mot internet bör man genast tänka om då man ser att data från denna exponerats eller till och med exfiltreras utanför IT-miljön. Det är även viktigt att snabbt kunna se avvikelser från till exempel förväntad kontoinloggning och beteendemönster i dessa. Det är viktigt att teamet som jobbar med att övervaka nätverket besitter aktuell övergripande kunskap om de kommersiella cyberhot som de olika angriparna utövar. Detta för att fastslå vissa karakteristiska signaturelement av angreppet så att man snabbt kan förstå att nätverket kompromettерades, samt vem eller vilka som ligger bakom det. Detta görs för att kunna föregå angriparens eskalering i nätverket och orsaka vidare skada(Miloslavskaya, 2018).

2.2.4. Respons

Det är av yttersta vikt att man säkerställer att det finns en beprövad incidentresponsplan(Enoch *et al.*, 2020). De olika roller och funktioner som inkluderas i denna plan behöver vara beprövade och informerade på korrekt sätt, samt att det är viktigt att alla i de inkluderade rollerna tar ett gediget ansvar. Ju mer man har övat på sin plan, desto större är chansen att man lyckas avvärja en IT-attack, givet att ens plan sällan till fullo verkställs utan det är de inövade rutinerna som medför bättre respons. Det är ur ett utbildande syfte vettigt att här ha använt sig av så kallade Red Team:s, d.v.s. en typ av pentestfunktion. I dessa Red Team:s jobbar inhyrda säkerhetskonsulter med organisationens hela IT-miljö, som för dem i förväg kan vara okänd . Målet för Red Team:et är i förväg bestämt, och kan vara att exempelvis få åtkomst till miljön och kunna exekvera kod på en server (med systembehörighet) eller uppnå en viss behörighet för att kunna åstadkomma annan typ av skada. Tanken är att upptäcka både sårbarheter men även träna organisationens egna motståndskraft och handlingsplan inför en skarp händelse.

Här är det viktigt att man snabbt avgränsar angriparens möjligheter att fortsätta röra sig fritt mellan nätverkets enheter, att man undviker att angriparen implementerar bakdörrar för fortsatt redundant inträde till nätverket samt att man i den mån det är möjligt avbryter angriparens intrång (Werlinger *et al.*, 2010). Detta steg handlar om att stoppa hotaktören

från att eskalera attacken. Den vanligaste metoden för att säkerställa att angriparen inte rör sig fritt inom nätverket är att man kopplar bort de infekterade enheterna eller på annat sätt begränsar dem från den övriga miljön. Det enda sättet en hotaktör kan skada nätverket utan att ha åtkomst till det i händelse av att den infekterade enheten begränsas är om hotaktören förberett sig för detta genom att exempelvis schemalägga hur nästa bakdörr skall implementeras, eller genom att automatiskt köra viss kod i en server eller dator. Innan man raderar script och andra verktyg som används av hotaktören skall en forensisk undersökning genomföras för att säkerställa att angreppet har avvärjats.

Det är viktigt att man efter att en responshantering ägt rum tar sig tiden att uppdatera protokollen och arbetsmetoderna, så att man står än mer redo inför nästa gång(*UK National Cyber Security Centre*, NCSC, 2022). Det är även viktigt att alla intressenter inom eller utanför bolaget får snabb och korrekt information om händelsen utifrån den mottagande partens behörighetsgrad och intresse.

2.2.5. Återhämta

Annat än att återställa sitt system är det i detta steg viktigt att hantera incidenten på ett korrekt sett(*UK National Cyber Security Centre*, NCSC, 2022). Det är viktigt att man kommunicerar med sin omvärld (t. ex kunder, leverantörer eller aktiemarknad) på ett professionellt sätt som även ligger i linje med vad som kallas för regelefterlevnad just utifrån det land organisationen opererar i. Det ligger i den utsatta organisationens intresse att efter en ransomwareattack förstår hur och varför hotaktören lyckades ta sig in, detta för att kunna förhindra en liknande attack i framtiden. Att hålla eventuella säkerhetshål i sin exponerade attackyta kontinuerligt uppdaterade och patchade är också av yttersta vikt för att fortsättningsvis förhindra en attack. Att gå igenom hur och på vilket sätt man kunde återställa systemen m.h.a. backup:s är också av stor vikt, så att den punkten kan förbättras inför en ny eventuell attack. Slutligen kan en viktig aspekt vara att se till att organisationens personal besitter korrekt kunskap för att förhindra att bli attackerad på nytt, detta gäller särskilt om attacken initierades av olika typer av phising där angriparen använt Social Engineering som verktyg.

De ovanstående stegen är ett vedertaget ramverk för hur en incidentresponsplan bör se ut, självklart så kan denna anpassas beroende på organisationen. Efter ett angrepp kan organisationen med stor fördel återgå till steg 1, där det är viktigt att NIST:s ramverk

används som en iterativ arbetsmetod. Denna metod bör även användas iterativt trots att ett angrepp inte har skett.

2.3. Kryptering

Kryptering har historiskt vanligtvis använts för att kunna överföra data (data in motion) eller lagra data (data at rest) med målet att utomstående inte kan avläsa datat medan det skickas mellan ett nätverks olika noder eller då datat lagras lokalt på en enhet (Sletten, 2016). Det finns dock en anomali kring att kryptera lagrad data i mångt och mycket. För att lagrad data ska kunna dekrypteras måste krypteringsnycklarna tillfälligt finnas inom IT-miljön den används i, vilket i sin tur gör de exponerade i en eventuell attack. Därför kräver krypterad lagrad data att krypteringsnycklarna återfinns utanför nätverket, vilket i realiteten blir en mycket svårlöst infrastruktur.

Kryptering utförs med hjälp av en förutbestämd matematisk algoritm som beskriver hur datat (i binärform) skall kodas om till obegripligt data och även hur detta sedermera skall avkodas och då återgå till att bli läsbart i klartext (Kee *et al.*, 2017). En eller flera, privata eller publika, nycklar krävs för att kunna kryptera och dekryptera datat vilket blir garanten för vem som kan läsa datat efter kryptering. Då kryptering kan anses vara grunden i all digital säkerhet läggs det otaliga resurser på området från vitt skilda samhällsaktörer såsom organisationer, hackare och statliga aktörer där både utveckling och förstörande eller knäckande drivkrafter föreligger.

I avseendet ransomware används dock kryptering i ett förstörande syfte eftersom man "låser" offrets data med hjälp av en eller flera krypteringsnycklar (Min *et al.*, 2022). Detta gör att den som krypterar någon annans data kontrollerar vem som skall få tillgång till dekrypteringsnycklarna. I en fullbordad ransomwareattack är angriparens mål att kryptera offrets data så att endast angriparen själv kan utläsa innehållet, och då hålla datat som gisslan tills betalning för dekryptering erhålles och den angripne återfår tillgången till sitt data.

Olika krypteringsfamiljer, algoritmer och metoder har ständigt utvecklats, och är en direkt följd av att datorer och annan hårdvara blivit allt kraftfullare över tid (Sletten, 2016). För att kryptering skall anses säker brukar man säga att det med dagens tillgängliga hårdvara skall ta tillräckligt lång tid att bryta krypteringen. Detta kan ske genom att krypteringsalgoritmen

antingen har inneboende säkerhetsbrister eller att man lyckas gissa rätt på krypteringsnyckeln genom att testa alla tänkbara möjligheter, även kallat bruteforce. Hur lång tid det tar att knäcka ett krypto beror dels på vilken längd krypteringsnycklarna har, vilken typ av kryptering som används och hur säker krypteringsalgoritmen är (med avseende på inneboende säkerhetsbrister), samt vilken typ av hårdvara den som försöker knäcka krypteringsalgoritmen/nyckeln besitter. Det finns även andra arbetsmetoder för att knäcka en kryptografisk nyckel, såsom att man undersöker hur krypteringsnyckeln genererats. Detta hänförligt till svårigheten kring att generera rent slumpmässiga tal.

Det finns två huvudsakliga krypteringsmetoder som implementeras för att skydda data från att kunna avläsas av obehöriga, samt en tredje närbesläktad metodik till sedvanlig kryptering:

2.3.1. Symmetrisk kryptering

Vid symmetrisk kryptering används samma kryptografiska nyckel vid kryptering som vid dekryptering, eller att man med en ytterst enkel manipuleringstransformation kan gå mellan respektive nyckel (Cloudflare, 2023). Eftersom att både den som krypterar och den som dekrypterar symmetriskt krypterat data behöver ha tillgång till samma nyckel finns det en inneboende säkerhetsbrist i hur man skall leverera dessa (god krypteringsed är att kontinuerligt uppdatera de kryptografiska nycklar man använder sig av, annat än då nya nycklar skapas) på ett säkert vis med tillräckliga säkerhetsgarantier kring att obehöriga personer inte får tillgång till den kryptografiska nyckeln.

Symmetrisk kryptering lämpar sig väl vid kryptering av stora datamängder, då krypteringsalgoritmerna ofta består av relativt enkla och korta matematiska funktioner samt att den kryptografiska nyckeln som används ofta är av relativt kort längd vilket snabbar upp krypteringsmetodiken. Det finns idag även till stor del inbyggt krypteringsstöd i datorers processorer, vilket effektiviserar denna krypteringsmetod avsevärt.

Vidare är symmetrisk kryptering inte lämplig då det krypterade datat skall delas mellan fler parter än två, då samma krypteringsnyckel skulle behöva återanvändas av flera parter (Nakov, 2022). Den idag vanligast förekommande symmetriska krypteringsalgoritmen är AES, men även alternativ såsom Twofish, Salsa20, DES, 3DES, m fl är frekvent använda algoritmer.

2.3.2. Asymmetrisk kryptering

Vid asymmetrisk kryptering använder man ett krypteringsnyckelpar, d.v.s. ett relaterat par av nycklar där varje nyckelpar består av en publik och en privat nyckel (Cloudflare, 2023). Den publika nyckeln kan distribueras helt fritt till hela världen, så att vem som än önskar kan kryptera ett meddelande åt en utan att påverka säkerheten i krypteringsalgoritmen. Med hjälp av den privata nyckeln kan sedan endast den som meddelandet blivit krypterat för dekryptera datat, således behöver den privata - hemliga - nyckeln aldrig transfereras mellan olika enheter eller personer.

Säkerheten i asymmetrisk kryptering begränsas av hur säker man kan hålla den privata nyckeln, så fort den privata nyckeln är avslöjad kan man anta att hela krypteringskedjan är bruten och det krypterade datat bör anses läckt (Salil Vadhan, Harvard University). Dessa egenskaper gör att asymmetrisk kryptering i många avseenden är att betrakta som säkrare än symmetriska diton. Ofta är nycklarna i asymmetriska nyckelpar längre än motsvarande symmetriska nycklar och tiden det tar att kryptera asymmetriskt är vanligtvis avsevärt längre än för de symmetriska metoderna. De kryptografiska algoritmerna består av enkelriktade matematiska manipulationer av datat, vilket innebär att det är tämligen enkelt att beräkna den matematiska funktionens värde åt det ena hållet, men å andra sidan är det ytterst krävande att beräkna funktionens invers givet utvärdet där målet är att finna ingångsparametrarna och på så sätt avläsa datat. Vad som anses som “enkelt” eller “krävande” bestäms av komplexitetsteori (beräkningskomplexitet), där de matematiska problemen innehar en viss polynomtid.

Den idag mest frekvent använda asymmetriska krypteringsalgoritmen är RSA (Nakov, 2022), men även alternativ såsom ElGamal och DSA används beroende på situation. Vidare finns det en hel sub-familj av asymmetriska algoritmer, benämnd elliptisk kurvkryptografiska algoritmer, som är under starkt ökande popularitet och här läggs det idag stort fokus på att utveckla och implementera de nya algoritmerna då de har möjlighet att erbjuda snabbare kryptering och mindre over-head size. Vanligt implementerade elliptiska kurvkryptografiska algoritmer är exempelvis NIST:s P-256 eller Ed25519/X25519.

Möjligheten att knäcka en krypteringsalgoritm beror dels på algoritmens inneboende säkerhetsbrister, där det eventuellt skulle kunna gå att reverse-engineera de matematiska beräkningar som utförts, men även på vilken typ av hårdvara man har (Nakov, 2022). Ju snabbare man kan utföra beräkningar i en dator, desto snabbare skulle man kunna testa alla tänkbara nycklar och på så sätt dekryptera det data man vill åt. Inom ämnet kryptografi pratas det mycket om den beräkningskraft kommersiella kvantdatorer skulle ha den dag det eventuellt förverkligas. En kvantdator skulle teoretiskt kunna bruteforce:a krypteringsnyckeln på ett sätt en vanlig dator inte har resurser till (givet att krypteringsnyckeln genererats av en vanlig dator). Konsekvenserna av detta är att många av de krypteringsalgoritmer vi idag känner till blir för osäkra för att kunna tillämpas säkert under den övergångsperiod då data eventuellt krypteras av både vanliga datorer och kvantdatorer samtidigt. Samma diskussion håller även för att krypteringsnycklar skulle bli mångdubbelt så säkra om de beräknades med hjälp av den beräkningskraft en kvantdator eventuellt skulle kunna ha, och då bli det närmaste omöjlig att knäcka med annat än just en kvantdator.

I de attackanalyser som publicerats kan man tydligt se att de ökända ransomwarehotaktörerna har som vana att använda tämligen softisikerade krypteringsvanor, där krypteringen av offrets data ofta sker med hjälp av både symmetrisk och asymmetrisk kryptering (s k hybridkryptering), samt där hashfunktioner återkommande förekommer av olika skäl i de utvecklade ransomware-scripten (Counter Threat Unit Research Team, Secureworks, 2017). Detta beror rimligtvis på att man önskar få med både den tidseffektiva fördelen med symmetrisk kryptering, då det ofta är en stor infrastruktur som så snabbt som möjligt behöver krypteras innan offret upptäcker vad som sker, samtidigt som man vill ha den förhöjda säkerheten i asymmetrisk kryptering samtidigt som man vill kunna erbjuda offerspecifika nycklar för de verktyg och ransomware-script man använder på offrets enheter, både utifrån kryptering- och dekrypteringstekniska aspekter.

2.4. Hashfunktioner

Även om det teoretiskt går att använda enbart asymmetrisk kryptering för att signera eller validera signaturer är det hashfunktionens vanligaste användningsområde att just - med hjälp av även ett asymmetriskt chiffer - kunna validera data eller på annat sätt generera en kontrollsumma över en viss datamängd (Nakov, 2022). Detta kan exempelvis användas för att säkerställa att ett meddelande som skickats inte blivit manipulerat längs vägen genom att

hashsumman signeras asymmetriskt, detta sparar både tid och resurser i de fall där meddelandet i sig inte behöver kommuniceras krypterat. En hashfunktion är en fullt deterministisk funktion som alltså varje gång man stoppar in ett givet datapaket i den genererar exakt samma utvärde, hashsumma. På så sätt kan man exempelvis kontrollera att data som skickas (data in motion) förblir oförändrat både från oavsiktliga fel eller annan manipulation längs datapaketets resa. En säker hashfunktion måste matematiskt vara enkelriktad och kollisionsresistent. Exempel på vanligt förekommande hashfunktionsfamiljer är SHA-2 och SHA-3, där den förstnämnda innehåller hashfunktionen SHA-256 som är den vanligast förekommande hashfunktionen i olika tillämpningar där säkerhetsaspekter är av betydande karaktär.

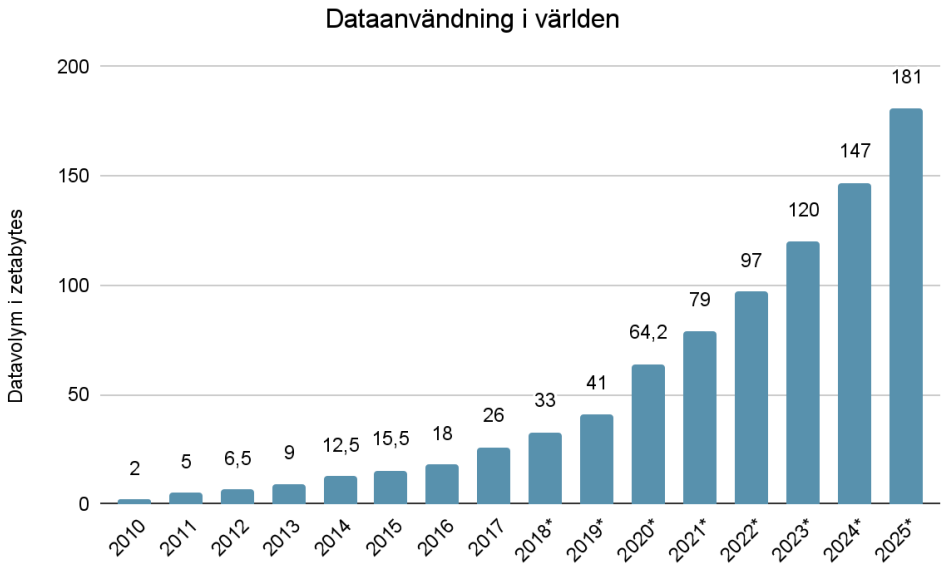
2.5. Regelefterlevnad

Regelefterlevnad innebär att som enskild (privatperson eller organisation) i allra högsta mån se till att uppfylla de förväntningar som ställs på en utifrån de lagstadgade krav och andra regler som finns.

2.5.1. Chat Control

Chat Control är ett nytt förslag, framlagt av EU, som tvingar organisationer med digitala tjänster att övervaka all form av kommunikation för att sedan dela denna data med olika myndigheter (Fröjd, 2022). Skribenten menar att införandet av denna form av övervakning kan skapa både problem och nytta. Anledningen till lagförslaget var att minska sexuella trakasserier på sociala medier, däremot finns problem vid implementering av detta utifrån ett datasäkerhetsperspektiv. Fröjd (2022) nämner hur implementeringen av det nya förslaget leder till en hantering av data som kan vara känslig och/eller skyddsvärda. *”Eftersom förslaget kommer leda till behandling av stora mängder personuppgifter som riskerar vara både känsliga och särskilt skyddsvärda, såsom barns personuppgifter krävs att det finns en laglig grund för personuppgiftsbehandling.”* skriver Fröjd. Skribenten nämner även den potentiella problematik som kan uppstå med ett införande av detta lagförslag. *”Förslaget innebär att data skulle delas med och lagras hos privata Leverantörer av interpersonella kommunikationstjänster samt både nationella myndigheter och organ på EU-nivå.”* skriver Fröjd och följer upp med att nämna att detta är, enligt Europadomstolen, en begränsning av rätten till integritet.

År 2023 förväntas det att internetanvändare skickar 120 miljarder terabyte data över hela världen (Statista, 2021). Enligt Statista (2021) har användningen historiskt sett ökat och förvantas att fortsätta göra detta framöver, se Figur 1.



Figur 1. Dataanvändning i världen från år 2010 till 2025. En zetabyte motsvarar en miljard terabyte. Asterix indikerar estimat. Hämtad från statista.com, 2023-05-09.

2.5.2. GDPR och övrig regelefterlevnad

Den 25e maj 2018 infördes GDPR - General Data Protection Regulation - av Europeiska Unionen (GDPR.eu). Lagstiftningen är världens största av sitt slag, och påverkar inte bara organisationer inom EU utan alla organisationer över hela världen som riktar sig till EU-medborgare (Fröjd, 2022). Överträdelse av lagstiftningens standarder innebär kraftiga bötesbelopp för de överträdande organisationerna. Lagstiftningen är i förlängningen ett överstatligt samarbete för att se till så att alla EU-länder håller samma standard, dessförinnan så var det upp till varje enskild nation att tillgodose sin egen datalagstiftning. Förordningen är en av många som beskriver vem vars data som berörs av förordningen, hur denna data skall hanteras (både in motion samt in rest), hur den får lagras samt om/när den är aktuell att inte längre ha kvar.

Exempel på övriga datasäkerhetsprotokoll förknippade med regelefterlevnad är ISO-27001. Denna standard är den mest välkända standarden gällande datasäkerhet (Internationella standardiseringsorganisationen, 2022). Standarden innehåller delar som berör datasäkerhet och, enligt ISO, ger organisationer riktlinjer på hur man etablerar, implementerar, underhåller och förbättrar sin datasäkerhet. Misslyckande att följa denna standard innebär att organisationen är icke-certifierad, vilket kommer ge negativa konsekvenser gentemot organisationens intressenter. För att uppnå denna standard krävs det att en organisation skapar och implementerar ett datasystem för att sedan anses certifierade (IT Governance, 2022).

2.6. Ransomware as a Service

Allteftersom att ransomware har kommit att bli en dominant attackmetod så har även det så kallade Ransomware as a Service kommit att växa. Ransomware as a Service bygger på att flertalet aktörer är inblandade i operationen, där man delar (säljer) sin prestation vidare till andra aktörer i värdekedjan på ett franchise-liknande vis (Per Håkon Meland, 2020). Två viktiga förutsättningar för att Ransomware as a Service skapats sägs vara de två plattformarna (1) kryptovaluta (Yacoob *et al.*, 2017) och (2) darknet. Darknet är en ljusskygg del av det öppna internet, där man använder verktyg för att förbli och kommunicera på ett anonymt sätt.

Ransomware as a Service ger en oerfaren datoranvändaren möjlighet att ensamt ingå i en del av den kedja som sedermera opererar ett ransomwareangrepp, samtidigt som toppskiktet inom denna värld av brottssyndikat förbli skyddad bakom de hotaktörer som väljer att köpa dessa tjänster. Riskbilden och konsekvenserna av denna decentraliserade marknad är att en enskild anställd potentiellt kan välja att sluta upp med en RaaS-aktör och initiera en ransomwareattack från insidan, eller att det blir desto svårare att kartlägga denna cyberkriminalitet. Under de tre första kvartalen 2019 bedömer Europol (Europol, 2019) att RaaS-marknaden omsätter så mycket som en (1) miljard USD, vilket troligtvis ökar i samma takt som ransomware i övrigt.

3. Metod

Följande avsnitt kommer att beskriva arbetsgången för detta arbete. De viktigaste delarna av avsnittet är sektion 3.3 och 3.4, där de valda organisationerna för intervjuer kommer att beskrivas. Detta anses vara den viktigaste delen eftersom denna branschs utveckling sker kontinuerligt, vilket medför att det är otroligt viktigt att se hur organisationerna jobbar mot ransomware-angrepp idag för att kunna analysera detta mot teorin som skrevs för ett antal år sedan.

3.1. Teoretisk referensram

IT-säkerhet har varit fråga för diskussion allt sedan datorns uppkomst, däremot har ransomware kommit att bli ett stort växande problem och oftast den mest kostsamma typen av angrepp sett utifrån en organisations arbete. På grund av ransomwares moderna inslag, att angreppen ständigt blir fler och mer aggressiva, har vi valt att enbart fokusera på denna typ av angrepp. Att inkludera fler typer av attacker mot organisationer i en sådan här studie skulle leda till att studien blir alldeles för omfattande då det finns fundamentala skillnader mellan de olika typerna av IT-angrepp.

Vid sökning av teori var den viktigaste kopplingen att den hade med IT-säkerhet att göra. Sedan har den information som relaterat till just ransomware använts. Sökord som frekvent använts hittas i slutet på detta delkapitel.

Sökord: IT-säkerhet, cybersäkerhet, ransomware, hotaktör, kryptering, backup, datasäkerhet, GDPR, Chat Control, multifaktorautentisering, Patch Management, SOC, pentest, bruteforce.

3.2. Tillvägagångssätt

Det första som gjordes för studien var att genomföra en litteraturstudie, för att få en djupare inblick i det rådande kunskapsläget gällande IT-säkerhet och det aktuella problemet ransomware. Det blev uppenbart, relativt tidigt i arbetet, att det rådande kunskapsläget är i kontinuerlig förändring. Detta innebär att publicerad vetenskaplig litteratur som publicerades för bara tre år sedan redan nu är utdaterad, p.g.a. att denna bransch har en snabb förändringskurva. Detta blev uppenbart via möten med handledarna från Säkerhetskontoret. Det har även blivit uppenbart att denna bransch har en otroligt hög

sekretessgrad, då all publikation kan nå angripare som då kan utnyttja dessa för att hitta nya attackytor i IT-system. Efter att litteraturstudien genomförts skall även intervjuer med organisationer inom branschen genomföras. Detta för att ge nutidsblick över hur organisationer arbetar mot IT-angrepp.

Intervjuerna har gjorts i enlighet med Bryman och Bell (2017) där en intervjuguide skapades, däremot anses öppna frågor vara mer givande i detta område med dessa respondenter. Däremot har de frågor som inte besvarats ställts direkt från intervjuguiden för att säkerställa att alla frågor får ett svar. Efter detta kommer respondenten även få tillfälle att revidera sina uttalanden, där möjlighet ges att stryka eller ändra information som har delgivits, för båda parters tillfredsställelse. Respondenten kommer även få tillfälle att tala helt fritt kring området, för att möjliggöra relevanta sidospår.

Efter att intervjuerna var genomförda och empiri och analys var skrivna skedde revision av den teoretiska referensramen. Detta för att ge läsarna en djupare förståelse när detta ämne tas upp i resultatet. Samt för att leverera en högre kvalitet på arbetet.

3.3. Beskrivning av organisationer

Det gemensamma för de organisationer som ligger till grund för denna studie är att de samtliga jobbar aktivt mot aggressiva angreppsmetoder. Antingen jobbar organisationerna på uppdrag åt andra kunder, eller så besitter de själva känslig data som behöver adekvat skydd för att inte riskeras gå förlorat i en attack.

3.3.1. Säkerhetskontoret

Säkerhetskontoret jobbar på uppdrag åt andra organisationer, vars huvudsakliga uppdrag härrör offensiv eller defensiv säkerhet. Exempel på de typer av uppdrag man utför är pentester och andra typer av behörighetseskalerande sårbarhetsanalyser, för att säkerställa att uppdragsgivaren är säkra nog mot de hot som hotaktörer ständigt presenterar. Även källkodsanalys och reverse engineering utförs. Säkerhetskontoret jobbar på uppdrag åt både privata organisationer och myndigheter.

På Säkerhetskontoret intervjuades tre respondenter, Claes Törneman, Jerry Illikainen och Jesper Svensson. Törneman är VD på företaget och har tidigare erfarenhet av arbete på Försvarets Radioanstalt FRA. Illikainen är en pentestare, det vill säga att han tar sig in i

Säkerhetskontorets kunders system och nätverk, för att hitta möjliga säkerhetsmässiga svagheter. Svensson är även han pentestare och kryptograf och arbetar främst med forensisk undersökning av ett attackerat nätverk. Han har tidigare reverse engineerat ett antal ransomwareattacker.

3.3.2. PartnerSec

PartnerSec är en organisation vars huvudsakliga arbete utgörs av integration av APV-system(Access, Payment, Visitor). Dessa APV-system är cloud-baserade. Cloud-infrastrukturen är tillhandahållen på egen hårdvara, vilket medför att det krävs god kunskap om IT för att bedriva en framgångsrik organisation.

Organisationen arbetar även med att projektleda och installera säkerhetssystem. De besitter kunddata som är av hög sekretessgrad och är alltså ett stort potentiellt offer för ransomware-angrepp.

På PartnerSec har två respondenter intervjuas. Den första är företagets VD, Jenny Spencer, och den andra är deras CTO och säkerhetsansvarig, Erik Öhnell. Intervjun hölls med båda respondenterna samtidigt då de hade olika infallsvinklar och kunskapsnivåer. Spencer svarade framförallt på organisatoriska frågor medan Öhnell gav ett mer tekniskt perspektiv på de frågor som ställdes.

3.3.3. Truesec

Truesec är en koncern vars uppgift är att erbjuda de bästa och mest heltäckande skydden och verktygen för organisationer i Norden. Truesec opererar globalt, men har sin största kundbas i Norden. Man erbjuder alltifrån sedvanliga pentester, till Red & Blue Teams och man tillhandahåller även en egen SOC-verksamhet. Man har även tjänster för att exempelvis scanna IP-range och upptäcka opatchade system åt sina kunder. Man erbjuder även tjänster såsom att utföra säkerhetskontroller på personal åt kunder. Organisationens kunder är vanligtvis större privata organisationer. Koncernens företrädare syns ofta i media då de tillför sakkunskap till aktuella samhällsfrågor.

På Truesec har två respondenter intervjuas, Mattias Wåhlén och Mats Hultgren. Wåhlén är en underrättelseanalytiker och har tidigare erfarenhet inom statlig organisation. Hans arbete har sin grund i att förstå hotaktörerna och riskerna samt trenderna kopplade till dessa. Med

Wåhléns kartläggning skapas bättre förutsättningar för att skydda sina kunder, samt förutspå och förstå omvärlden. Hultgren är Director of Operations för incidentresponsenheten på Truesec. Hultgren arbetar med incidentrespons, samt att han föreläser och utbildar verksamheter och ledningsgrupper samt styrelser i cybersäkerhetsfrågor.

3.3.4. Murphy Solution

Murphy Solution AB levererar kvalificerat kompetensstöd inom krishantering, kontinuitetshantering, riskhantering, säkerhetsskydd, informationssäkerhet och civilt försvar till både privata och offentliga verksamheter inom alla sektorer och alla nivåer - från enskilda förvaltningar, till kommuner, regionala och sektorsansvariga myndigheter och nationella myndigheter, liksom små lokala företag upp till multinationella koncernbolag.

Stödet som ges sker både förberedande och förebyggande, men även som rådgivande stöd under akuta kriser och som kvalificerat utvärderingsstöd efter skarpa händelser eller övningar. Murphy Solution arbetar alltid enligt vedertagna metoder såsom ISO-standarder och nationella och internationella vägledningar, guidelines och principer för ledning, krisledning, kontinuitetsplanering och riskhantering, informationssäkerhet, säkerhetsskydd och civilt försvar. Centralt för deras verksamhet är devisen om det praktiska lärandets effekt för att uppnå förändring.

På Murphy Solution arbetar ett team av konsulter med olika bakgrunder. Alla företagets seniorkonsulter har praktiskt haft roll som stabschef/krisledare i kvalificerade krisorganisationer. Det här betyder att Murphy Solution inte bara har teoretisk förståelse för vad krisberedskap är eller metodkunskap, utan även djup förståelse för den verklighet som de ska implementeras i och hur viktigt resultaten är för det systematiska arbetet.

Från Murphy Solution AB har en respondent intervjuas, Elin Richarz, som är medgrundare för företaget. På företaget arbetar hon som Senior Rådgivare inom Krishantering och Kontinuitetsplanering.

3.4. Urval av organisationer och respondenter

De respondenter, deras respektive organisation och roll inom organisationen samt längd på intervjun listas i tabell 1.

Tabell 1: Sammanställning av respondenter

Organisation:	**Respondent:**	**Respondents roll:**	**Intervjuplats:**	**Intervjulängd:**
Säkerhetskontoret	Claes Törneman	VD	Digital	70 min
Säkerhetskontoret	Jerry Illikainen	Offensiv pentestare	Digital	70 min
Säkerhetskontoret	Jesper Svensson	Pentestare & kryptograf/reverse engineer	Digital	52 min
PartnerSec	Jenny Spencer	VD	På plats	75 min
PartnerSec	Erik Öhnell	CTO & Säkerhetsansvarig	På plats	75 min
Truesec	Mattias Wåhlén	Underrättelseanalytiker & Threat Intelligence Expert	Digitalt	77 min
Truesec	Mats Hultgren	Director of Operations för incidentrespons	På plats	120 min
Murphy Solution	Elin Richarz	Medgrundare & Senior Rådgivare	Digital	52 min

3.5. Analys av empirisk data

Den empiriska datan har analyserats genom transkribering av intervjuerna för att sedan koda dessa och hitta relevanta nyckelord och teman. Dessa teman lägger grunden för det resultat som presenteras i kapitel 4, såsom *Ransomware 3.0, Kryptovaluta, GDPR, Patch Management, Implementation av Backups, Dataskydd, RaaS* och *Konstant Övervakning*. Dessa teman är valda på grund av att de förekommer i samtliga intervjuer och för att det är dessa teman som anses vara en stor bidragande faktor till utvecklingen inom branschen. De lägger även grund för de slutsatser som dras, samt att de påvisar de områden där fortsatt forskning krävs. De slutsatser som dras från detta arbete tillhör skribenterna, som rådfrågat samtliga handledare för arbetet. Även här är det uppenbart att fortsatt, samt kontinuerlig, forskning krävs då branschen är i konstant förändring. Den information som i denna studien fastslås antas vara inaktuell i en snar framtid, därför är det relevant att nya studier ständigt utförs.

3.6. Kvalitetsmått

För att i den mån det är möjligt kunna säkra studiens kvalitet, har studiens teoretiska referensram diskuterats i ett tidigt ständigt skede med studiens handledare. Detta för att säkerställa att arbetet håller sig till relevanta nutida modeller, teorier samt litteratur då

branschen är väldigt snabbföränderlig. Kvaliteten i teorin är särskilt bekymmersam vad gäller gränssnittet mellan den publicerade, väl vedertagna, litteraturen och den information som finns att tillgå i branschen rent “hands on” då industrin ligger före det vetenskapliga som hinner publiceras av akademin. Vidare är intervjuerna förstås baserade på enskilda individers sakkunnighet, varpå en viss partiskhet givetvis kan tänkas förekomma. Det är därav viktigt att ha klart för sig vad en eventuell respondent kan tänkas ha för intressen i informationen vi delges. Att basera denna studie på litteratur och intervjuer med bland de bästa i landet på detta område inger hög reliabilitet och validitet.

Vad det gäller det faktum att det idag finns metoder för att till viss del knäcka (eller på annat sätt förbigå) de tillämpade kryptografiska metoderna, utövade av hotaktörer i ransomwarattacker, så är vår uppfattning att detta är en så pass känslig del av säkerhetsorganisationernas metoder att vi ej kan få insyn. Vi har givetvis full förståelse för detta med avseende på detta arbete. Att diskutera dessa bitar i detta arbete vore ren spekulation och tillför därför varken akademiskt eller praktiskt bidrag.

4. Empiri & resultat

I detta avsnitt listas de resultat som har framkommit från de intervjuer som har genomförts med respektive organisation. De teman som har framställts listas som underrubriker och har genom varje intervju diskuterats.

4.1. Ransomware 3.0

Detta tema nämndes enbart av en organisationerna som förklarar fenomenet på följande sätt.

Truesec

Till en början så var den utarbetade metoden vid ransomwareattacker från hotaktörernas sida att kryptera offrets miljö. I takt med att fenomenet ransomware har kommit att öka har även metoderna blivit alltmer sofistikerade. Ransomware 2.0 går ut på att hotaktören både krypterar och stjäl datat, detta gör att offret kan bli dubbelutpressad, alternativt att offrets data riskerar att exponeras till utomstående obehörig part. Ransomware 3.0 går ut på att man inte krypterar, utan istället helt förstör offrets filsystem efter att man har gjort en backup. Denna backup försöker hotaktören sedermera sälja tillbaka till offret, med hot om att man annars kommer att offentliggöra datat.

Truesec ser tecken på att istället för att kryptera offrets data så raderar man all offrets data och sedan säljer tillbaka en backup. Problemet med denna metod - som i praktiken är mycket svår att tillämpa och som ännu inte slagit igenom - är att detta kräver otroliga datalagringsmöjligheter för hotaktörerna. Detta nämns av både Wåhlén och Hultgren. Trots att Hultgren nämner detta som en tes och inte en trend så är det något att hålla ögonen öppna för, säger han.

4.2. Kryptovaluta

Kryptovaluta är en slags digital valuta, utan styrande eller kontroll av en ensam makthavare såsom en stat eller centralbank. Respondenter förklarar att kryptovalutans garant är kryptografiska matematiska metoder där varje transaktion valideras genom nätverkets uppbyggnad. Konsensusen är distribuerad och uppfylls med hjälp av blockkedjor över ett P2P-nätverk. En ökad penningmängd kan uppnås, men endast enligt de direktiv som kryptovalutan skapats enligt. Eftersom kryptovalutor är decentraliserade medför de att transaktionerna som sker kan hållas någorlunda konfidentiella, åtminstone till den grad att

man endast kan se till/från vilken plånbok pengar skickas men aldrig vem som är den egentliga plånboksinnehavaren. Om samma plånboks-ID återanvänds, skulle detta kunna leda till att ett visst plånboks-ID på så sätt kan knytas till en viss aktör. Den mest frekvent använda kryptovalutan, tillika den äldsta, vid ransomware förmodas vara Bitcoin (BTC), då det är förhållandevis kommersialiserat att kunna växla över till denna valuta för offret.

Säkerhetskontoret

Kryptovalutor har möjliggjort för angripare att ta emot lösensummor och att organisationer gjorde detta om inte summan var för hög. Jesper Svensson menar på att angrepp mot organisationer som hade pengar kunde på ett enklare sätt genomföras anonymt med hjälp av kryptovaluta. Han säger *"Angriparna hade en guldålder där"*. På senare tid har standarden och rekommendationen blivit att inte betala lösesumman. Han nämner även att trots att de incidenter som uppkommer i dagsläget fortfarande är höga så betalas inte lösesumman lika ofta, för att extra arbete har lagts ner på att säkra upp systemen. Svensson tydliggör även att kryptovaluta har gett ransomwareangrepp möjligheten att utvecklas och utöka på det sätt som det har. Dock nämner han hur en del krypto-transaktioner har blivit spårbara och att detta då inte är lika säkert för angriparna.

PartnerSec

Respondenterna från PartnerSec förklarar skillnaden mellan ett virus och ett ransomware. *"Du fick ett virus, du körde ett antivirus så var det borta. Du fick ett malware som gjorde din dator sjutton gånger långsammare, fan vad jobbigt. Eller att de installerade en cryptominer som drog resurser."* säger Erik Öhnell. Han fortsätter med *"Men egentligen hade det ingen ekonomisk bäring än tiden det tog att återställa, men ett ransomware, det står ju liksom en bitcoin adress. Betala till det här. Det är inga små belopp heller."* Han fortsätter med att nämna hur ett stort företag med produkter från kameror till skrivare betalade 40 miljoner dollar för ett ransomwareangrepp.

Truesec

Mattias Wåhlén menar på att innan ransomware blev en riktigt stor grej, 2017, så fanns cyberkriminalitet fortfarande, men de som på den tiden greps för cyberbrottslighet även var inblandade i penningtvätt av olika slag. Detta har kommit att förändras i och med att penningtransaktioner numera kan göras på ett mer anonymt vis samtidigt som transaktionerna kan skötas från vitt skilda ställen på jordklotet med hjälp av

kryptovalutornas framväxt. *"..helt fundamental del av utvecklingen av ransomware. Att det är lätt att hantera kryptovaluta."*.

Ett sätt som Wåhlen framhåller som starkt begränsande mot ransomwares framfart är att införa större globala restriktioner på kryptovalutor. Om det blir svårare att hantera lösensummor anonymt kommer affären och den ekonomiska vinningen i ransomware att upphöra och problematiken och riskerna upphör till stor del. Detta håller även Hultgren till viss del med om, däremot nämner han svårigheter med att totalt anonymisera kryptomarknaden och påstår att om ett tillvägagångssätt (till exempel dagens kryptovaluta) stängs ner kommer nya alternativ snabbt att utforskas och skapas. Hultgren menar att *"Nature finds a way"*.

4.3. GDPR & regelefterlevnad

Vad som är gemensamt för respondenterna från samtliga organisationer är att de menar att GDPR-lagstiftningen har ökat medvetenheten för vikten av ett säkert IT-system. Det blev än tydligare att kunddata inte får lämna EU, och vissa fall inte Sverige. I och med införandet av sådana restriktiva regler finns det numer krav (regelefterlevnad) på hur och var data lagras. Vad de respektive organisationerna och respondenter har sagt beskrivs nedan.

Säkerhetskontoret

Säkerhetskontoret säger att GDPR ökar medvetenheten för vikten av IT-säkerhet och att denna relativt nya lag har genererat fler incidentresponser. Jesper Svensson säger att den tidigare mentaliteten där organisationer tänker att ingen hotaktör vill angripa dem har försvunnit på grund av denna lag. Han nämner även att Säkerhetskontoret har varit ostrukturerade, men att de har blivit mer strukturerade och fått fram en bra mall för hur de ska arbeta med incidentrespons på grund av de nya lagar och ramverk som framställts. *"Inte bara organisationer var omedvetna för fem år sedan, även vi var det"* säger han. Svensson nämner även att GDPR har på ett sätt tvingat organisationer att göra olika tester, såsom pentester, för att se till att de åtminstone följer de krav som ställs av denna lag.

Illikainen nämner att många bolag vill bli certifierade enligt ISO-27001 för att kunna säga att datahanteringen sker säkert. Detta upplevs emellertid kunna handla om att endast leva upp till en viss standard för sakens skull, där han upplever att en stor del av certifieringsprocessen handlar om att efterleva påfundade regelverk där en byråkrat får i uppgift att införa en annan byråkrats påfund, varpå man upplever sig säker utan att faktiskt

vara säker.

PartnerSec

Eftersom PartnerSec är en organisation som behandlar kunddata åt en bred skala av kunder kan kunddatan variera i känslighet. Jenny Spencer säger att en del av deras kunder kräver att deras data enbart får lagras inom Europa och Erik Öhnell fyller på med att det finns ett fåtal kunder som kräver att deras data lagras i Sverige. Respondenterna belyser även hur bötesbeloppet då man inte följer GDPR har ökat, som nu ligger på nästan 20 miljoner kronor, och att detta är en av de främsta anledningarna till att organisationer säkrar upp deras IT-system. Öhnell säger *"Det värsta är inte om våra servar hamnar under ransomware, utan det värsta som kan hända är att våra kunders data hamnar någon annanstans och någon kan bevisa detta."* Han lägger även till att, utöver den stora bötessumman, medkommer immateriell skada och förlusten av förtroendet från kunderna. De belyser även problematiken av användning av Microsoft tjänst Office 365, samt Google och Amazon, som är amerikanska företag och, som Öhnell förklarar *"...microsoft är ett amerikansk bolag och enligt den amerikanska federala skyddslagen så är alla amerikanska bolag oavsett verksamhetsområde skyldiga att dela data med NSA."* Han belyser faktumet att detta är varför inga kommuner använder sig av dessa tjänster.

Truesec

Mattias Wåhlén på Truesec menar på att det finns den typ av kunder som helt förlitar sig på att köpa IT-säkerhetstjänster enbart för att själva inte tänka på den frågan. Detta är en form av outsourcing där man ger iväg ansvaret till någon och litar på gör att de gör jobbet bättre än en själv i något avseende. Här föreligger ibland en ansvarsproblematik där båda parter i en sådan situation kan anse att det är den andras fel. Dessa kunder kan t. ex känna att IT-säkerhet inte är en av bolagets kärrnfrågor, utan att man vill ge iväg denna ansvarsroll till en extern part.

Wåhlen framhåller dessutom den potentiella utpressningsvägen där hotaktören använder hot om att offentliggöra offrets bristande arbete i enlighet med GDPR som en möjlig utpressningsmöjlighet där man hotar offret med att meddela myndigheter om dess bristande arbete om lösesumman ej erlägges.

Mats Hultgren förklarar hur många bolagsstyrelser ser på IT-säkerhet och menar att deras syn är att IT-säkerhet är en ren kostnadsfråga och inte en prioritering för att hålla sin

infrastruktur säker. Han belyser problematiken med detta då det ger organsationer en felaktig blick av vad som behöver göras. Han nämnde ett samtal han haft med ett företag där CFO var ansvarig för IT-systemen då *"det är en ren kostnadsfråga."*

Murphy Solution

Richarz menar att eventuellt exfiltrerad data redan är att betrakta som förlorad enligt de regelverk som finns. Många styrelser i organisationer "har panik" över situationen där man försöker förstå de risker som finns hänförliga till eventuella dataläckor och de regelkrav som ställs.

Richarz pratar även om vikten av att faktiskt kommunicera med ens intressenter på ett vettigt sätt. Den som sköter detta väl, i samband med en vidare bra hantering, kommer att belönas av att förtroendet för adekvat agerande och ärlig kommunikation bibehålls, och i de fall organisationen är publikt noterad även leda till högre aktiekurs. *"Kriser kan stärka verksamheten om de hanteras på rätt sätt"*.

4.4. Patch management

Ett uppdaterat system är ett säkrare system, menar respondenterna. System och mjukvara där nya patcher (uppdateringar som åtgärdar de säkerhetshål som upptäckts) släpps skall hållas uppdaterade. Patcher är menade för att blockera säkerhetshål, svagheter, och att inte hålla dessa uppdaterade äventyrar inträde till hela systemet. De organisationer som intervjuats har bidragit med nedanstående information.

Säkerhetskontoret

Säkerhetskontoret ger en tydlig bild om att många organisationer brister i sin patch management. Att ha tydliga rutiner för hur och när (men även av vem och i vilken grad det sker automatiskt eller inte) patchning går till, menar Säkerhetskontoret är grundläggande för att upprätthålla ett säkert system. Trots att organisationer har blivit bättre på patch management så är det ett kontinuerligt arbete, som Svensson menar behöver bli ännu bättre. Han säger *"Man borde ha någon som är ansvarig för den biten."* Anledningen till bristerna i patch management är att organisationer är rädda att en uppdatering kommer göra att deras system inte längre funkar, menar Svensson. Framförallt kan detta uppstå hos äldre organsationer där den ansvariga för uppstarten av infrastrukturen har lämnat oorganisationen och kunskapen hos den som efterföljer är bristande. Svensson menar på att istället för att

byta ut infrastrukturen till en ny, förhoppningsvis säker, infrastruktur så bygger man på det som är okänt. *"Det spelar ingen roll om du har en ståldörr om du har ett fönster bredvid, det är bara att krossa glaset och hoppa in"* säger Svensson.
Illikainen på Säkerhetskontoret säger att den gemene kunden varken har horribel eller jättebra patch management, att det finns en del att göra där.

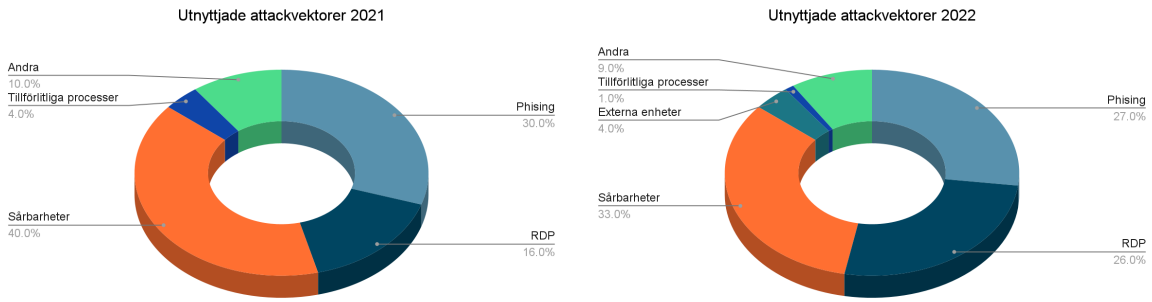
PartnerSec

PartnerSec förklarar patch management som en serie med ostskivor som har hål i sig. De menar att om det enbart finns en ostskiva med tre hål i sig så finns det tre möjliga attackytor för en angripare att ta sig in. Lägger man då till en till ostskiva med två hål och orienterar denna så att det inte finns en rak väg igenom har man ökat skyddet. Dock krävs det inte bara en eller två ostskivor, utan en serie. Respondenterna menar på att denna serie med ostskivor kommer att fortsätta öka i antal då man hittar nya säkerhetshål, samt att ju känsligare organisationen är ju tjockare behöver "ost-filtret" vara.

Truesec

Mattias Wåhlén belyser att man som organisation kanske sitter med 10-15 år gamla system, eller "lapp-på-lapp-system" där det är mer eller mindre omöjligt att gå in och uppdatera systemet på ett önskvärt vis. Det är vanligt att Truesec jobbar på uppdrag åt en kund där systemen ser ut på ett sådant sätt. Det är enkelt att som utomstående söka igenom alla världens uppkopplade servrar menar Wåhlen, m.h.a. detta kan man sedan upptäcka opatchade system varvid man potentiellt kan angripa dem. Det är av yttersta vikt att man har en fungerande patch management för att undvika att sårbarheter utnyttjas som attackvektor. Oftast sker patch management inte automatiskt, utan organisationerna har till exempel "Patch Tuesday" vilket medför problematik, detta är för att man inte alltid vet hur man skall skapa automatiska rutiner för att undvika att vara opatchad och sårbar.

Mats Hultgren nämner att den vanligaste attackvektorn under 2022 var sårbarheter i ett system, se Figur 2. Han nämner också att en angripare tar den lättaste vägen in i ett system och att detta har bidragit till den statistik som han refererar till. Han nämner även hur ett uppdaterat system har varit välkänt som ett säkrare system än andra, men att det inte är en uppenbarhet. Han liknar detta med hur COVID-19 pandemin gjorde det uppenbart att det lättaste sättet att hålla sig frisk är att tvätta händerna med tvål och vatten.



Figur 2, visar statistik över attackvektorer som Truesec hänvisar till. Hämtad från Truesecs "Threat Intelligence Report 2023" 2023-05-09.

Murphy Solution

Richarz menar på att det som var säkert för fem eller tio år sedan, inte är säkert idag. Detta innebär stora sårbarheter för organisationer om de ansvariga inte är förmögna att förstå varför viss hård- eller mjukvara behöver uppdateras för att hålla miljön säker, då hotaktörerna vet vad dessa sårbarheter finns och hur man kan utnyttja dessa. Richarz menar att en av de viktigaste preventiva medlen som finns mot ransomware är att se till att man är fullt uppdaterad, med korrekt licenser osv. Detta då opatchade hål kan vara en attackvektor, och då inte lämna dessa sårbarheter ohanterade.

4.5. Dataskydd

Att skydda den data man har i sitt nätverk är viktigt, både utifrån att angripare ej ska kunna stjäla denna men även för att obehöriga inte ska kunna råka få tillgång till denna menar respondenternna. Det optimala vore om man kunde kryptera både data in rest (lagring på server exempelvis) och data in motion (d v s data som skickas/kommuniceras mellan olika maskiner) menar merparten av respondenterna. Nedan följer hur respondenterna uttalat sig i frågan.

Säkerhetskontoret

Säkerhetskontoret menar att data in motion (kommunikation) bör krypteras, men att det i praktiken kan bli svårt att kryptera data in rest då detta i någon mening kräver att nycklarna (åtminstone vid varje dekryptering) finns tillgängliga vid tidpunkten för dekryptering vilket teoretiskt gör att en hotaktör skulle kunna äga även en sådan krypteringsmetodik. Svensson nämner fenomenet Ransomware 2.0 och stärker vikten av att både backuper och data in rest

ska vara krypterade för att den data som stjäls inte ska kunna säljas vidare och användas av andra, såsom konkurrenter. Han nämner även hur angriparnas krypteringmetodik har utvecklats de senaste fem åren. Förut hittades ett flertal fel i olika krypteringsmetoder som gjorde det möjligt att dekryptera data som var krypterat genom ransomware genom reverse engineering, men idag är metoderna så pass bra att det nästan är omöjligt att dekryptera. Han säger *"Vi väntar på kvantdatorerna för att kunna göra det."*

Svensson talar om cybersäkerhetsbranschen och dess ständigt utvecklade metoder för att motstå cyberkriminaliteten med att berätta om hur pass segmenterad produkterna och tjänsterna idag är. Han säger *"I dagsläget är det mer som en Schweizisk armékniv än ett rostigt blad som det var för fem år sedan."* med vilket han menar att det idag finns många olika metoder på samma verktyg att tillvarata.

PartnerSec

PartnerSec använder sig av en lokal filserver för att dela data mellan varandra. Denna server är krypterad och ickeåtkomlig för någon utanför nätverket. De nämner även att man inte kan RDPa in sig i nätverket, utan att det enda sättet att komma åt nätverket är att vara på plats. Denna filserver backupar till en molntjänst, som är outsourcad av PartnerSec. Denna leverantör säger att datan är krypterad i vila, och för att komma åt den krävs det en krypteringsnyckel som inte ens PartnerSec vet vad den är. De har tillgång genom att de prenumererar på tjänsten. De har även en lokal fysisk kopia på denna backup som också är krypterad. De nämner även att alla datorer använder BitLocker och har TPM-chip för att låsa ner dem. Detta gör att ifall hårdvarustöld sker medan hårdvaran var i ett avstängt läge så kommer hotaktören inte att komma åt data utan att ha vetskap om krypteringsnyckeln. Eftersom det inte går att komma in på PartnerSec:s nätverk utanför deras kontor anser de att kommunikationen på nätverket inte behöver vara krypterad.

Truesec

Hultgren menar på att det är av stor vikt att korrekt kryptering tillämpas på viktig data, men även data i allmänhet. Han pratar särskilt om att kommunicerad data skall skyddas av kryptering även fortsättningsvis, trots att Chat Control diskuteras. Han menar att Chat Control bara riskerar att drabba den oskyldige då hotaktörer tillika cyberbrottslingar även fortsättningsvis kommer att kryptera sin kommunicerade data vid eventuellt införande av sådant förbud.

Vidare menar Hultgren att nätverk måste byggas totalt isolerat från varandra för att vara så säkra som möjligt. Viss typ av hårdvara får endast vara uppkopplade till ett förutbestämt nätverk, där kommunikation mellan nätverken sker genom att människan fysiskt behöver överföra datan nätverken emellan. *"Det behöver bli svårare igen för att göra det säkrare"* säger Hultgren. Han förespråkar även starkt isolering och segmentering av olika identiteter för varje användare, där varje specifikt syfte (både privat och i tjänst) har egna inloggningskonton eller virtuella miljöer för att öka skyddsnivån.

Vidare så förklarar Hultgren att när en hotaktör väljer att påbörja krypteringen av infrastrukturen så saknar hotaktören helt intresse i att stänga ned aktiva processer på korrekt vis utan man påbörjar snarare krypteringen medan exempelvis servrar och databaser snurrar för fullt. Detta jämför han vid att dra i handbromsen medan man kör i 300km/h på en motorväg - saker kommer att paja. Detta gör att data (uppemot 30-35%) kommer att gå förlorat även om offret väljer att betala hotaktören lösesumman.
Slutligen så anser Hultgren att det är av ytterst vikt att man tillämpar MFA på ett systematiskt vis, *"användarnamn och lösenord är 70-tal"* (Hultgren). Han anser att man helst tillämpar även autentisering med fysisk hårdvara, där han lyfter fram lösningen YubiKey som en smidig lättanvänd men ändå säker produkt. Däremot belyser han nackdelarna med enbart mjukvaru-MFA där en enda lagrad cookie skulle kunna äventyra autentiseringsprocessen.

Dessutom lyfter även Hultgren fram att människan är mångfacetterad i termer av att vi är en enda person, men med flera olika profiler. En tydlig attackyta hos människan som social varelse är att om man börjar utpressa eller hota den privata personen så kommer man att nå någon slags måluppfyllnad i att samma person kan tänkas handla på ett visst sätt utifrån sin yrkesroll. Här tas skräckexempel upp på hur enkelt det är att söka upp ett offerföretags ledning, välja ut en av dem samt sedan söka upp personen och dess familj på exempelvis Facebook för att sedan komma med hot om att ens familj kommer att fara illa om ens organisation inte erlägger lösensumma. Detta kan exempelvis mitigeras genom att man inte har offentliga sociala medier (åtminstone inte med publika bilder eller familjekontakter), eller vidtar annat specifikt personskydd där det anses adekvat.

Som tidigare nämnt i kapitlet *Metod* så finns det viss typ av empiri i detta arbete som ej kan

förklaras på en djupare nivå av olika skäl. Den empiriska informationen är hänförlig till denna källa och detta tema.

Murphy Solution

Richarz nämner att mörketalet är mycket stort, endast en bråkdel av alla angrepp blir offentliga och uppmärksammade i media.

Richarz menar att korrekta behörigheter på de som har tillgång till nätverket är en av de viktigare protokoll att upprätthålla för att säkerställa att miljön hålls skyddad. Man måste helt enkelt ha koll på vem som har vilken behörighet. Om man ger alla full behörighet till allt är det otroligt svårt att upprätthålla bra dataskydd. Ansvaret bör fördelas på dels cheferna, där chefen hålls fullt ansvarig för de behörigheter anställda har, samt att konton som tillhör anställda som slutat skyndsamt tas bort. Man behöver ha god förståelse för att detta sammankopplar till riskbilden. Även de som administrerar IT-miljön behöver ha god förståelse för hur och vem som beslutar om behörigheter, samt att de själva behöver vara insatta i riskbilden.

IT-säkerhet och IT-säkerhetsrisker är inte en IT-fråga. Ingen verksamhet i Sverige är oberoende IT, detta gör att förmågan att upprätthålla IT-driften är kopplad till IT-säkerhet. Men en IT-säkerhetsincident kommer inte enbart att belasta eller påverka IT-förmågan utan hela verksamheten och organisationens överlevnadsförmåga. IT-säkerhetsfrågan och den riskbild som den för med sig skall ligga högst upp på alla ledningsbords prioriteringslista.

Inte bara MFA, utan kanske även fysisk hårdvara anser Richarz vara vettigt som autentiseringsmetod. Vidare bör data lagras krypterat för att säkerställa god säkerhetsrutin. Det finns olika anledningar att vilja skydda ens data, och beroende på vilken typ av data man hanterar kan olika typer av kryptering tänkas tillämpas. Är man exempelvis skyddsklassad kanske man inte skall lagra digitalt data alls om den bedöms som känslig för verksamheten, om den inte skyddas på rätt sätt.

4.6. Implementering av backup

Backup är en väsentlig del av en organisations säkerhetssystem, menar alla respondenter. Att inte bara ha backup, men att ha flera backup på olika platser är också av stor vikt. Åtminstone en kopia skall sparas fysiskt och offline, för att kunna återställa detta utan risk

att obehörig manipulerat kopian. Dock är det viktigt att man kopierar hela systemet (d.v.s. inkl system-konfiguration) och inte bara de filer man använder. Vad respondenterna har sagt hittas nedan.

Säkerhetskontoret

Backups menar Säkerhetskontoret är viktigt att utföra enligt ett tydligt protokoll. Detta ska helst ske så automatiskt som möjligt, och lagras på olika medier om möjligt. Både offline och eventuellt i molntjänster för att underlätta processen. Jesper Svensson anser att backuper ska vara snapshots och att dessa ska tas dagligen, för att minska förlusten vid ett angrepp. Han beskriver att för känsligare data ska man inte kunna skriva över det. Detta kan göras med hjälp av band där data skrivs och sedan är det printat utan möjlighet för överskrivning. Han belyser också att detta inte är applicerbart för alla former av organisationer.

Svensson förklarar även att för fem år sedan låg en organisations backup i deras infrastruktur, vilket han menar är lönlöst då en angripare har tagit sig in i det, och att idag är organisationer bättre på att separera nätverk och backuper. Han nämner att det finns brister i hantering och test av återställning av backuper. Han menar att ett flertal av Säkerhetskontorets kunder har en testmiljö där de kan göra olika former av tester, såsom pentester, och att denna miljö även kan användas till att testa att backuper går att återställas. *"Man skickar iväg sina backuper och hoppas att de ska fungerar som de ska"* säger Svensson.

Jerry säger att när han tidigare jobbat med backups i sin yrkesroll är det uppenbart en svår fråga att handskas med då backups är krävande att tillämpa på ett bra sätt. Det är viktigt att man vet att de fungerar när de behövs för återställning, och att riskerna hänförliga till backups mitigeras så att alla backups inte ligger på samma ställe. Man bör distribuera sina backups i enlighet med det organisationens verksamhet tillåter, t. ex lokalt eller i molnet. Återställningen av backups behöver en icke-automatisk process med visst manuellt arbete, i en miljö där det är okej att allt havererar.

PartnerSec

PartnerSec belyser användningen av backups för organisationer som handskas med kunddata. De nämner att det finns avancerade backups som har inbyggt ransomware-skydd.

De menar att backupsystemet kan identifiera när det sker många förändringar i filer och då stänger ner möjligheten för detta. Erik Öhnell säger även att systemet sparar de tio senaste versionerna och att det då är enkelt att återfå originalfilen. Respondenterna belyser även vikten av att ha flera backuper, på olika ställen. Dock nämner de även att detta är dyrt då backuper tar betalt per lagringsenhet, om detta är gigabyte eller terabyte. Trots att PartnerSec är ett litet företag har de mycket data som kan behöva lagras. På grund av detta har de skapat ett arkiv med filer som de vet inte används längre, för att komma ner i lagringsenheter till backuper. Jenny Spencer säger att det är svårt att göra detta. *"Grejen är att när man är ett företag så här så vet man inte, man vågar ju inte radera saker. Man tänker att det kanske är någon som använder det här."*

PartnerSec använder sig av backups, på olika sätt och på olika ställen, däremot belyser de utmaningen av att testa att dessa går att återställa på en liten organisation som behöver ha ett konstant uppkopplat system. Erik Öhnell säger *"...även om vi är ett ganska litet företag så innebär det ju i princip att inget skulle kunna göras inom normala arbetsuppgifter för att datan man använder inte finns tillgänglig."* Han belyser även problematiken med att återställa det till en isolerad miljö, han säger *"...men man har ingen av stressen, man har ingen av tjänstebortfallet eller att telefonerna går varma."*

Truesec

Mattias Wåhlén menar att backups är en absolut nödvändighet för att kunna återställa ens infrastruktur i händelse av ransomwarangrepp. Korrekt backuphantering inkluderar externa offline-backups. Mats Hultgren nämner 3-2-1-metoden för att ha en korrekt backuphantering. Man ska ha tre olika backups, på två olika medier (t. ex cloud eller egen hårdvara) varav en ska vara offline. Han nämner även vikten av att ha cloud-kopian utanför infrastrukturen, eftersom om den ligger på infrastrukturen kommer en angripare ha tillgång till denna vid ett angrepp.

Mattias Wåhlén belyser att det är ytterst viktigt att man även har testat och vet att en återställning kommer att fungera, eftersom det oftast är mycket stor data som skall återställas vid ett angrepp. Detta är något som även Mats Hultgren belyser. Han menar att ett flertal organisationer provar att återställa ett fåtal filer och då antar att hela backupen fungerar. *"Assume nothing"* säger han och menar på att det är när man börjar anta saker som det havererar. Wåhlén upplever tydligt att det finns bristande rutiner och kunskap kring hur

man bygger upp en effektivt fungerande backuphantering ute hos kunderna. *"Det är väl en kombination av okunskap och oförstånd. Man vet inte att man inte vet. Det finns tyvärr många företag fortfarande som tänker att det här händer inte mig."* Det finns en tydlig konsensus kring att det är för dyrt och omständigt/verksamhetsdrivande att göra rätt för sig de gånger man är medveten om att man inte har adekvat backup-rutin.

Hultgren nämner även att det är viktigt att förstå att för att återställa en backup krävs det 100% kapacitet och att det då kan innebära att organisationer raderar den infekterade versionen för att återställa till en tidigare version. Han menar på att man absolut inte ska göra detta, då den infekterade versionen krävs för forensisk undersökning. Den forensiska undersökningen behöver göras för att få uppfattning av hur angriparen tog sig in i infrastrukturen, då detta är nödvändig information för intressenter, såsom försäkringsbolag och/eller kunder.

Murphy Solution

Inom incident response ligger att återstarta och återskapa miljöer enligt Richarz. Detta är inte en av Murphy Solutions arbetsuppgifter, däremot bistår de med kompetens till den utsatta organisationen och dess IRT/CSIRT. Ett exempel på detta är upprättanded av kontinuitetslösningar, kommunikationsstrategier och att krisleda verksamheten. Efter detta bistår Murphy Solution även med specialiserad utvärdering för att skapa lärande i efterperspektiv.

Backups är inte ett skydd mot ransomware, men är en viktig förutsättning för att kunna återskapa miljön vid ett angrepp. Användningen av backups är en viktig förutsättning, ibland den enda, för att kunna återskapa data, och de bör vara verifierade. Det ger inte en hundraprocentig täckning, men är A och O. Respondenten förespråkar 3-2-1-metoden, där man lagrar flera olika backups på flera olika lagringsmedier. Man behöver även testa att sina backups går att återläsa och att det går felfritt till. Man behöver kunna återläsa hela systemkonfigurationer, innan man kan börja återläsa själva datat som skall återskapas.

4.7. Konstant övervakning

Konstant övervakning av ens IT-infrastruktur sägs vara en av de bättre metoderna för att tidigt kunna upptäcka ett intrång, menar respondenterna. Det råder dock delad mening bland respondenterna om huruvida detta skall utföras. Nedan följer respondenternas uttalanden.

Säkerhetskontoret

Ett flertal respondenter från Säkerhetskontoret nämner att det bästa sättet att upptäcka och skydda sig mot ransomwareattacker är att ha en SOC (*security operation center*), samt att man har ett bra segmenterat nätverk. Det finns idag inga vedertagna automatiska verktyg som är vettiga utifrån övervakande syfte, utan den bästa lösningen är människor som gör detta.

PartnerSec

Respondenterna från PartnerSec förklarar att de har en avancerad brandvägg som loggar all form av anomalitet som de själva klassar som anomalitet. T.ex att försöker logga in från någon plats utanför Sverige, då de bara har verksamhet i Sverige. Utöver detta kollar även Erik Öhnell, som är säkerhetsansvarig, regelbundet vilka klienter som är uppkopplade, för att se om det är någon klient som han inte känner igen, eller som har konstigt namn. De nämner även att de har investerat i övervakningsverktyg, som automatiskt skickar ut varningar om det är någon anomalitet som sker. De belyser även problematiken då det kommer till konstant övervakning. De förklarar att det finns en koppling mellan övervakning och att detta kan göra det svårt för personal att arbeta, om man begränsar deras användning. Erik Öhnell säger *"Någonstans nu är vi tillbaks det här, vad är rimligt och inte..."* De nämner även problematiken med bring your own device. De menar på att det är lätt att installera appar eller program som kan skada organisationen. De nämner även att detta har en koppling till hur restriktiv man ska vara med användningen av organisationsenheter, Jenny Spencer säger *"Just eftersom, gör man det för krångligt, kommer folk bli uppfinningsrika och göra det lättare för sig själv."* och Erik Öhnell följer upp *"Så det är en fin linje där emellan, liksom att det ska vara tillräckligt säkert men ändå säkert på ett sätt som gör att folk inte börjar ta risker."*

Truesec

Truesec:s övertygelse är enligt Mattias Wåhlén att man aldrig kommer kunna återfinna (åtminstone ännu) ett bättre övervakningssystem än ett sådant som opereras av människor. Han menar på att det är vanligt förekommande att cybersäkerhetsspecialister erbjuder automatiserad övervakning, där man inkluderar någon slags nymodighet såsom AI, men att detta sällan är särskilt adekvat skydd i realiteten. Wåhlén lyfter även fram problematiken kring att företagsledare, eller de med ansvar över organisationens IT-säkerhet, sällan förstår

de argument “tekniksidan” lyfter fram som risker kopplade till IT-angrepp. Han menar att man behöver måla upp en mer konkret situation så att kunderna inser värdet av att ha adekvat övervakning och skydd. Det finns tre vanligt förekommande attackvektorer: phishing, opatchade system och kompromitterande inloggningsuppgifter. För att säkerställa adekvata skydd och övervakning måste man ha MFA menar Wåhlen. Hultgren nämner även att ett bra skalskydd inte är tillräckligt. För att uppnå ett säkert system krävs det att man har ett bra skalskydd, men att denna ska förstärkas med övervakande av system och en responsplan. Han säger *“Det spelar ingen roll hur höga murar man bygger eller hur djupa vallgravar man gräver, nature will find its way.”* Han belyser även hur det pågående kriget mellan Ryssland och Ukraina har lärt oss att det är viktigare att ha bra överblick och upptäcksförmåga för att kunna säkra upp sin infrastruktur.

Murphy Solution

Richarz menar att *“var och vartannat IT-leverantörsbolag anser sig vara experter på incident response och övervakning",* vilket gör det svårt för en okunnig kund att veta vilket typ av skydd man bör skaffa sig. Hon menar även att många IT-företag har byggt upp egna övervakningstjänster, vilket gör att det är svårt att veta som kund vilken förmåga man faktiskt har eller inte då alla i branschen anser sig vara bäst. Richarz tar upp exemplet att det är lätt att tro att man har övervakning av sin miljö, men att man bara har det under vanlig kontorstid, beroende på vilket avatal eller vilken typ av tjänst man har valt. Detta menar hon har gjort att produktutvecklingen har gått fel. Skälet till att det kan bli så fel enligt henne är att det finns en okunskap hos beställaren, samt att kostnadsbilden av det hela gör att den billigaste lösningen vinner upphandlingen vilket går stick i stäv med att ”billigast är inte bäst”.

Richarz menar att man behöver ha en *“upptäckttjänst”* för att kunna bli varse, och få flaggor, när ett eventuellt angrepp sker. Detta behöver ske 24/7 365 dagar om året, annars har man “blinda hål” i ens miljö.

4.8. Ransomware as a Service & ekonomisk affär

RaaS är något som börjat märkas av i branschen under den absolut senaste tiden enligt respondenterna. Gemensamt för respondenterna är att de beskriver hur enkelt och billigt det är att köpa någorlunda moderna ransomware, helt utan att själv ha kunskaper om hur dessa fungerar. Man målar upp en bild av att det inte längre behöver vara dedikerade IT-personer

som initierar de enklare typerna av angrepp.

Säkerhetskontoret

Jesper Svensson nämner Ransomware as a Service i koppling till kryptering och nämner att ett stort fel som angriparna som köper ett ransomware gör är att de inte konfigurerar det på rätt sätt. Detta gör att istället för att kryptera en hel fil så krypteras endast en liten bit av filen, eller att ransomwaret kan kryptera oväsentliga delar av en databas, och att det då är lättare att reverse engineera kryptering. *"De har inte läst manualen"*, säger han. Han nämner dock att ransomwaret är välskrivet och att problemet då ligger hos den som försöker angripa, och inte hos författaren.

PartnerSec

PartnerSec belyser den ekonomiska vinningen som finns med ransomware. Erik Öhnell säger *"För i tjuvarnas intresse är det det handlar om, det handlar bara om pengar."*. Han fortsätter med att förklara att angriparna kan köpa ett ransomware från dark web för 500 dollar för sedan sätta upp ett botnätverk som skickar 100 phising mail och får ett napp och att vinningen från detta kan ligga uppemot 50000 dollar. De belyser också problematiken med att så länge det finns pengar i ransomware kommer det att fortsätta. Jenny Spencer säger *"Så länge vi inte kommer på något bra försvar så, med tanke på att det ligger så mycket pengar i det, så måste det ju till en situation där det inte längre lönar sig för att det ska sluta."*

Truesec

Mattias Wåhlén menar att hotaktörerna kan vara så pass softistikerade att de fungerar som ett vanligt företag. Han belyser att den största hotaktören han följt varit närmare 100 personer samt haft en egen HR-avdelning som betalat ut semesterlön. De stora effektiva brottssyndikaten är så pass välorganiserade för att lyckas med bedriften att angripa säkra och stora IT-infrastrukturer att utvecklingen av hotaktörens ransomware sker på ett parallellt löpande band. Man har olika avdelningar inom brottssyndikatet som gör olika delar i angreppet, med ständig över- och vidarelämning av uppgifterna. Detta beror på att det finns länder, exempelvis Ryssland, vars regering ser mellan fingrarna. Detta har lett fram till att de ryska hotaktörerna är så pass välorganiserade, menar Wåhlén, då det sedan länge har funnits en oskriven regel i Ryssland där den ryska regeringen ser mellan fingrarna vad gäller cyberbrottslighet så länge hotaktörerna endast håller sig till att angripa organisationer i väst.

Givet det rådande säkerhetsläget i omvärlden (med krig i Ukraina och säkerhetspolitiska spänningar därefter) menar Wåhlén att det är svårare än någonsin att få Ryssland att ingripa mot denna cyberbrottslighet som till stor del opereras av ryska hotaktörer. Under den första halvan av 2022 gick den ryska cyberbrottsligheten kopplat till ransomware ned med uppskattningsvis en tredjedel, troligtvis kopplat till de sanktioner som utfärdades mot ryska banker och övriga svårigheter kring att bedriva denna brottslighet på ett ekonomiskt välfungerande vis. Det finns troligtvis flera skäl till att Ryssland är överrepresenterat (90-95% av attackerna sägs komma från Ryssland) vad gäller ransomware-angrepp mot organisationer. Alltifrån att ryssar generellt kan tänkas ha en bättre kryptologisk utbildning till att staten är så svag och ser mellan fingrarna (eller att de struntar i det) till att cyberkunskapen behöver vara tillräckligt god bland tilltänkta brottslingar.

Vidare menar Wåhlén på att utvecklingen av ransomware och kopplingen till den ekonomiska vinningen är mångfacetterad, där det sedan 2021 finns exempel på hotaktörer som även stjäl datat de krypterar eller där man samtidigt utför DDoS-attacker på offren. Detta breddar den potentiella ekonomiska vinningen för hotaktörerna, då man åsamkar offret från flera kritiska håll på samma gång. Hela förfarandet handlar om att maximera chanserna för att offret skall betala lösesumman. Även hur och på vilket sätt man utformar lösesumman har utvecklats, där hotaktörerna gärna i förväg kollar om offret har en s k cyberförsäkring och vad denna kan tänkas erbjuda för utbetalning, vilket indirekt påverkar offrets betalningskapacitet.

Även för skyddssidan behöver åtgärder vidtas, menar Wåhlén. Det är av större ekonomisk betydelse att snabbt släppa en produkt (mjukvara) än att vara något långsamma som produktföretag men och andra sidan erbjuda det säkrare alternativet. Detta då det är det kunder anammar, man vill alltid ha det senaste så snabbt som möjligt.
Det finns en växande gig-ekonomi där olika hotaktörer köper och säljer olika cyberangrepp eller delar av dessa emellan varandra. Det är något som totalt sänker inkörsporten till att utföra denna typ av cyberangrepp. Som ensam individ behöver man längre inte vara en duktig hacker, då man enkelt kan vara en del av systemet istället. Hultgren håller med om detta och nämner även att dessa organisationer även befinner sig i ett välfungerande ekosystem, där köp och sälj av digitala identiteter pågår dagligen. Han menar även på att det enda som skiljer sig mellan en godsint och en ondsint hacker är etik och moral och att detta

har blivit än mer tydligt med uppkomsten av det ekosystem som skapats. Hultgren nämner också att det är enkelt att förstå varför en individ skulle vilja köpa ett ransomware och skicka till diverse företag, det är nämligen där pengarna finns. Eftersom de köpta ransomwares inte är lika sofistikerade som de som experterna skapar så menar han också på att det är bättre och/eller lättare att angripa 40 medelstora företag och kräva en lösesumma på 15 miljoner kronor än vad det är att angripa ett stort företag, som förmodligen har investerat i en SOC-verksamhet, och kräva dem på 150 miljoner kronor.

Hultgren belyser även att det är viktigt för företag, med uppkomsten av Ransomware 2.0, att vara transparenta vid ett intrång för att försöka ta bort det stigma som råder och för att kunna skapa en dialog om det växande problemet som är dataintrång. Han vill att skammen ska försvinna för att utsatta ska kunna vidta adekvata åtgärder. Medvetenheten kommer även att hjälpa utvecklingen av förståelsen för vikten av IT-säkerhet.

Murphy Solution

Richarz säger: *"Det finns en hotaktörsplattform som har lärt sig och förstått att den digitala världen är väldigt lättillgänglig och lukrativ ekonomiskt."*. Resultatet av detta är att ju mer digital data vi väljer att lagra eller kommunicera, desto större blir riskerna för offren men även den ekonomiska potentiella vinningen för dessa hotaktörer. Det finns även vissa branscher som kan tänkas vara mer utsatta än andra. Detta betyder att hotbilden för olika branscher ser olika ut och att de då kräver olika protokoll.

5. Analys & diskussion

Nedan följer en analys mellan vad samtliga respondenter har uttalat inom respektive tema ställt mot det material som presenterats i litteraturstudien, följt av en diskussion från arbetets skribenter kring detta där skribenterna lägger in personliga reflektioner.

5.1. Ransomware 3.0

Ransomware 3.0, som vi vill kalla den nya metoden som används av hotaktörer, är ett relativt nytt fenomen som presenterades i anknytning till intervjuer med Truesecs respondenter Wåhlén och Hultgren, därför finns ingen teori om detta i kapitel 2, *Teori*. Den teori som belyser utvecklingen av metoder för hotaktörer är skriven av Li och Liao (2020). Båda respondenterna nämner hur hotaktörerna sakteligen har börjat frångå att kryptera offrets filer och istället raderar dessa och sparar en backup, som de senare kräver pengar för att inte offentliggöra denna data. Detta är något som enbart har belysts av Truesec.

Inom det växande problemet att hotaktörerna, istället för att kryptera och stjäla, enbart stjäl och raderar en organisations infrastruktur är vår uppfattning att detta kan dröja tills det blir en trend att tala om. Li och Liao (2022) belyser Ransomware 2.0, som är den nuvarande trenden för hotaktörer. Den upptäckt som är Ransomware 3.0 visar tydligt att det krävs fortsatt forskning på om denna nya metod är den kommande trenden, samt för att belysa problematiken och potentiella lösningar för organisationer. Vi ser uppenbara nackdelar med detta då data kan tänkas landa hos ytterligare en extern part vid interimlagringen, möjligtvis utanför EU eller i fientlig stat. Här riskerar organisationen då att strida mot GDPR eller annan datahanteringslag och kommer då att eventuellt ställas inför en förödande sanktion. Detta på grund av att de kommer förlora pengar, samt att den tillit som organisationen byggt upp hos sina klienter kommer att förverkas på nolltid. Dock finns även fördelar kring Ransomware 3.0. En av dessa är att om en organisation har en väl fungerande backup-rutin kan de enkelt återställa sin verksamhet till en tidigare version. Här behöver de även inte tänka på att de behöver mer än 100% kapacitet då den infekterade versionen redan är borta.

5.2. Kryptovaluta

Samtliga respondenter nämner i någon form kryptovaluta och hur dessa har förenklat utbetalningar av lösesumma till angripare. Säkerhetskontoret och Truesec går än djupare in på dessa ämnen och diskuterar möjliga tillvägagångssätt för att göra det svårare för

angripare att behålla sin anonymitet vid dessa betalningar, men nämner även svårigheter med dessa potentiella lösningar. Till exempel nämner både Truesec:s respondenter, Wåhlén och Hultgren, att en start på detta kan vara att höja restriktionerna på användningen av kryptovaluta. Däremot nämner Hultgren att detta inte kommer att bli en permanent lösning då angriparna kommer att hitta nya möjligheter att bedriva denna form av cyberangrepp. PartnerSec nämner hur enkelt det har blivit för angriparna att få betalt, via en länk. Den intervjustudie som gjorts backas tydligt upp av litteraturen som presenteras som teori, där båda studierna tydligt klargör vikten av kryptovaluta som en del av ransomwaremetodikens förfarande. Både intervjurespondenterna och Yacoob *et al*.(2017) klargör att konfidentiella och smidiga penningtransaktioner är en vital del i cyberbrottslighet, inte minst inom ransomware där en stor del är att kunna utkräva offret på en stor lösesumma.

Kryptovaluta är enligt vår uppfattning en av de större bidragande faktorerna för den explosionsartade ökande trenden som är ransomware. Vi har fått en klar bild av att en restriktivare kryptomarknad skulle direkt påverka angriparna och dess förutsättningar, däremot krävs en konsensus från alla världens länder för att införa en sådan restriktion. Detta bedöms troligtvis omöjligt tillsammans med att man kan se kryptovaluta som en temperaturmätare på misstron hos det centrala banksystemet, vilket gör att om kryptovaluta försvinner så kommer ett nytt decentraliserat penningsystem snabbt att återkomma. För att hämma användningen av kryptovaluta krävs det att gemene man återfår sin tilltro till det traditionella penningsystem som tidigare har gett finansiell tilltro hos dess användare i flera decennier. Vi anser att alternativa penningsystem hämmar den ekonomiska utvecklingen genom att dessa pengar hamnar hos de kriminella istället för att hjälpa till att till exempel höja en stats BNP.

5.3. GDPR & regelefterlevnad

Det material som framkommit från intervjustudien saknar i stor grad uppbackning av den litteraturstudie som utförts när det kommer till just ramverket GDPR. Däremot återfinns en del litteraturmaterial, såsom IT Governance och Internationella standardiseringsorganisationen, gällande generell regelefterlevnad, då i termer av internationella standarder såsom olika ISO-koder samt hur de uppnås. Detta presenteras utifrån konceptet att det är svårt för en del organisationer att själva ha god kontroll på att man efterföljer de regler och krav som ställs, och att man därav tar hjälp av externa parter såsom säkerhetsfirmor där ansvaret tilldelas dem. Däremot pratar alla de

intervjurespondenterna vi talat med om vikten av GDPR som drivande faktor till ökat intresse för att faktiskt ha ett säkert IT-system. Inte sällan belyser respondenterna GDPR (samt generell regelefterlevnad) som den viktigaste faktorn till IT-säkerhetsbranschen snabba tillväxt. Richarz nämner även vikten av att vara öppen med ens intressenter vid ett eventuellt intrång och att det även kan vara fördelaktigt att vara transparent då det kan leda till högre förtroende från intressenterna.

Varför GDPR saknar relevans i den litteraturstudie som gjorts kan ha flera orsaker men troligtvis är den största faktorn att GDPR är en såpass ny och modern implementering att ramverket ännu inte hunnits diskuteras i den vetenskapliga publikation som skett. Att tala direkt med branschen och de människor som verkar i den ger en betydligt mer rättvisande bild av läget, vilket stärker vår tes om att regelverket faktiskt har stor pragmatisk inverkan. GDPRs inverkan på branschen bedöms stor, då det organiskt skapar en drivkraft åt att gå mot säkrare och mer medveten datahantering. Allt annat lika torde då datasäkerheten öka. Det återfinns även tecken på att diskrepansen är stor mellan den organisation som endast intresserar sig för regelefterlevnad (där stor korrelation bedöms finnas mot att samma organisation ser IT-/datasäkerhet som en ren kostnadsfråga) och den organisation som faktiskt intresserar sig av en hög säkerhetsnivå. Även om medvetenheten drastiskt ökar i takt med att sådana regelverk införs i likhet med GDPR, så är vår uppfattning att medvetenheten fortfarande bedöms för låg för att uppnå någon slags mognad och lägsta nivå inom branschen. Vägen att gå är fortfarande lång för de flesta organisationer, men det trendar definitivt åt rätt håll vad gäller totalskyddet mot IT-angrepp.

5.4. Patch management

Både den litteraturstudie och den intervjustudie som gjorts belyser samma funktioner i en organisations protokoll kring patch management. Det är tydligt från *UK National Cyber Security Centre* (NCSC, 2022) och på de respondenter som utfrågades att många organisationer har bristande rutiner i frågan, även om respondenterna ger en något mer positiv bild kring att det idag oftast inte ser varken förfärligt eller superbra ut. Både det som NCSC lyfter fram, samt de intervjuer som hållit har gjort gällande att fungerande patch management enskilt är en av de kritiska förmågorna i skyddet mot dessa hotaktörers kapacitet att penetrera ett nätverk. Mer specifikt lyfter både litteratur- och intervjustudien fram hur en effektiv patch management skall utföras, där observationer läggs fram såsom att en del organisationer fortfarande hänger kvar vid “Patch Tuesday” eller där patchning inte

sker eller initieras/flaggas för automatiskt. Detta ger en inneboende tidsfördröjning eller riskerar att inte göra nätverkets operatör varse om att patchning måste ske. Respondenterna lägger gemensamt låg vikt vid de så kallade zero-day-säkerhetshålen, då de inte bedöms vanligt förekommande i ransomwareattacker mot gemene organisation utan bedöms vara något som statsaktörer använder för betydligt viktigare mål med en helt annan avsikt eller ambition.

Patch management är i vår mening en av de viktigaste, om inte den viktigaste, faktorn för att upprätthålla ett säkert IT-system. Angripare kan enkelt ta sig in i ett opatchat system genom att läsa patch note:s (som regelmässigt publiceras då en patch publiceras) samt ha kunskap om vilken patchversion ett system innehar. Vår tro är att för att ha ett kontinuerligt uppdaterat system krävs det att IT-ansvarig är uppdaterad på de senaste publicerade säkerhetshålen (samt kritiskt kända familjerna av sådana) hos all den programvara som används inom organisationen. Det kan underlätta för denne om en automatisk flaggning skickas ut då det är i princip omöjligt för IT-ansvarig att ständigt inventera patchversionen på alla program och programvaror. Även anställda behöver bli bättre på att hålla kolla på den aktuella hotbilden, däremot är det IT-ansvarigas ansvarsområde att hålla varje enskild enhet uppdaterade. Detta kommer lägga större ansvar hos varje anställd att hålla end-point-hårdvara uppdaterad. En del anställda kan tänkas missa skälet till att hålla hårdvara uppdaterade och i dessa fall är det viktigt redan vid anställningen att denne blir informerad om vikten av att upprätthålla ett patchat system, samt att de bör få en kort introduktion till hur detta kan göras. Vår tro är att den största anledningen till ett dåligt patchat system är den mänskliga faktorn.

5.5. Dataskydd

Dataskydd är mer än bara kryptering i många meningar. Även om en hel infrastruktur är krypterad kan angripare hitta vägar att exfiltrera data. Att hålla en infrastruktur krypterad är, från ett datasäkerhetsperspektiv, god hygien, menar alla respondenter. Däremot råder delad mening om huruvida detta är praktiskt rimligt eller ens genomförbart hos respondenterna, då det i någon mening kräver stora tekniska och fysiska tillämpningar med särskilt goda säkerhetsprotokoll. Truesecs respondent Hultgren nämner Chat Control, som enligt Fröjd (2022) kan användas för att begränsa och/eller spåra brottslighet som möjliggörs av kryptering. Däremot så invänder respondenten sig mot detta ramverk på samma sätt som Fröjd (2022) och menar på att detta kan inskränka organisationer och individers integritet.

Säkerhetskontoret nämner även hur en krypterad miljö försvårar det fenomen som är Ransomware 2.0 då angriparen först behöver dekryptera offrets data innan de försöker sälja det vidare. PartnerSec belyser även problematiken då en angripare försöker stjäla en huvuddisk för att komma åt nätverket då en krypteringsnyckel krävs. Detta är något som Richarz håller med om, då hon nämner att fullständig kontroll på mjuk- och hårdvara krävs för att upprätthålla ett säkert IT-system. Respondenten nämner även hur ett fallerat IT-system kan innebära liv och död för en organisation.

Vår uppfattning är att de produkter och tjänster som finns idag har blivit alltmer välfungerande, men även mer segmenterade. Detta är ett tecken på att marknaden kontinuerligt mognar och produktutvecklingen följer denna mognad. Däremot finns fortfarande en lång väg att gå då branschen inte drivs av innovationer utan är en lek mellan katt och råtta.

Vår upplevelse är att många organisationer och individer har föreställningen att ett angrepp inte kommer att hända dem, samt att konsekvenserna för ett angrepp är obetydliga för just dem. Detta menar vi på är ett helt fundamentalt fel tankesätt då vem som helst kan råka ut för ett ransomwareangrepp (eller annan dataexfiltrering). Till syvende och sista så handlar detta tankesätt om att man i riskbedömningen inte vidtar skyddsåtgärder där risken för att hotet införlivas är likställd med noll. Vi är övertygade om att detta är ett oacceptabelt sätt att tänka på, då det krävs en risk- och konsekvensanalys för att veta vilken skyddsnivå man är bekväm med. En dataläcka får aldrig ens teoretiskt kunna förekomma, däremot bör alltid adekvata kris- och incidenthanteringsåtgärder finnas på plats, men att förutsätta en viss typ av händelse är hämmande i ambitionen av att motverka denna och blir totalt oacceptabelt.

I vår mening är kryptering en garant för hög integritet. Att kunna försäkra sig om att endast den som skapar datat, samt den tilltänkta läsaren kan komma åt datat skapar en högre grad av säkerhet inom informationssäkerhet. Digital integritet är viktigt utifrån många perspektiv, inte minst vad gäller demokratiska värderingar, såsom yttrandefrihet etc. För en organisation som besitter data är det viktigt att hålla den krypterad av samma skäl, men även för att angripare ej kan exfiltrera denna. Utan kryptering av data in rest är alla filer läsbara för den som har åtkomst till dem, vilket kommer att, i vår mening, öka risken för dubbelutpressning då angriparna kan sälja dessa filer direkt vid exfiltrering. Vår tekniska bedömning gällande kryptering är att all data (både in motion och in rest) skall krypteras för

att öka säkerheten och integriteten. Vår uppfattning är ändock att det finns vissa inneboende säkerhetsrisker vad gäller kryptering av data in rest, då nyckelhanteringen skall ske utanför nätverket. Vår bedömning här är att fysisk hårdvara förslagsvis används för nyckelhantering. Samma typ av fysiska hårdvara bör dessutom tillämpas som en autentiseringsmetod i ett välfungerande MFA-protokoll. Vi anser där särskilt god säkerhet krävs bör fysisk autentisering tillämpas, men som absolut minimum bör åtminstone två separata mjukvarulösningar förekomma (2FA) då autentisering genom användarnamn och lösenord inte uppfyller de krav/standarder som idag ställs. Mjukvarulösningar innebär risker i att dessa kan äventyras om exempelvis enheten som använde MFA blir stulen. Eftersom denna risk finns så behöver alla organisationer införa en form av informationsklassning, där man identifierar och klassificerar datats säkerhetsnivå för att kunna införa adekvata skyddsmetoder. Till exempel bör säkerhetsklassad information inte finnas på ett nätverk där kommunikation med omvärlden utanför organisation sker, då det är en attackvektor för hotaktörer. Det blir då en viktig del för anställda att vara medvetna om vilken information som har vilken säkerhetsklass, för att denna inte ska spridas till fel kanaler.

Vad gäller Chat Control är vår tes att detta är något som enbart kommer drabba den oskyldige. Med detta menar vi på att cyberkriminella fortsatt kommer att bedriva deras verksamhet utan större inskränkning av ett regelverk. De bedriver redan kriminella handlingar och kommer inte att oroa sig för ännu en lagöverträdelse. Vad gäller spårning av cyberkriminalitet så bedömer vi att den datamängd som idag skickas i nätverk är alldeles för stor för att kunna övervakas även om den tvingas ske okrypterad, vilket inte förbättrar möjligheten att begränsa kriminalitet utan istället inskränker integriteten för de som tvingas anpassa sig. Chat Control innebär en påtaglig risk för begränsning vad gäller visselblåsning och yttrandefrihet, vilka är starka grunder i en välfungerande demokrati.

5.6. Implementering av backups

Genom intervju- och litteraturstudie är det tydligt att backups behöver tas på samtliga system i en organisations infrastruktur, men det är lika viktigt att dessa backups testas att återställas från. I intervjustudien förekom viss diskrepans mellan vad de olika organisationerna sa. Säkerhetskontoret och Truesec håller med Malecki (2019) som säger att det är otroligt viktigt att testa att återställa från backups. Däremot belyser inte de problem som PartnerSec nämner, att testa att återställa på isolerad miljö inte tar in effekterna av stresspåslag och tjänstebortfallet. Dock blir dessa faktorer mindre vid ett angrepp om man

vid ett tidigare skede har testat att de fungerar, då man har skapat en erfarenhet av det. Däremot är samtliga respondenter eniga om att åtminstone en backup behöver finnas offline på extern hårdvara, otillgänglig att komma åt via infrastrukturen. Det nämns även en problematik med återställning från backups, då det krävs mer än 100% kapacitet för att ha originalsystemet igång, samt att återställa en tidigare version via backups. Genomgående i intervjuerna nämndes sällan risken att en dropper kan ligga kvar på en extern, offline, kopia av systemet, vilket enligt Malecki (2019) är värt att dubbelkolla. Det finns även en diskrepans mellan vad PartnerSecs VD Jenny Spencer säger angående radering av filer och vad NIST ramverk säger. NIST säger att filer som inte längre används bör raderas medan Spencer säger att det kan vara svårt att veta vilka filer som inte längre används. Både Richarz och Hultgren nämner 3-2-1 metoden, vilket ökar kredibiliteten som branschstandard, då det nämns av två respondenter på två olika organisationer. Både Richarz och Törneman påtalar vikten av att inte ens hantera data av högsta säkerhetsnivå som inte kan hanteras i en backup, de delar mening i att sådan data inte alls skall finnas i en IT-miljö (ens under arbetsförfarandet) utan hänvisar till andra alternativa bearbetningsmetoder.

Vår uppfattning genom litteratur- och intervjustudie, samt tidigare erfarenheter, är att backups är en total nödvändighet för att kunna återskapa ett system, inte bara utifrån fenomenet ransomware. För att kunna återskapa filer, program eller annat data krävs en tidigare backup-kopia. För att kunna undgå att betala lösesumma i en ransomwareattack är det enda rimliga alternativet att snabbt kunna återbygga systemet själv, vilket förstås i någon mening då kräver att ens data finns lagrat just i form av en backup. Det är ännu viktigare att faktiskt ha testat att ens rutiner för att återskapa backup-kopior fungerar, för utan vetskap om huruvida ens rutiner fungerar eller inte är vår generella uppfattning att en stor del av datat kommer gå förlorat och hela backup-rutinen förefaller vara meningslös. Även om en av de utfrågade organisationerna berättar om svårigheterna så är det i vår mening viktigt att man faktiskt ändå testar att återskapa, om än i en isolerad miljö, då all form av träning är bra träning. Däremot förefaller backup-återställning te sig annorlunda vid stresspåslag, och där tror vi att man bara kan träna så realistiskt som verkligheten tillåter. Till sin hjälp kan man välja att utöva kris- och incidenthantering med exempelvis sådana konsulter, vilket vi anser vara en absolut nödvändighet för de allra känsligaste organisationerna.

Det står helt självklart för oss att minst en backup-kopia behöver lagras helt offline, externt från den kopierade infrastrukturen. Det finns däremot flera olika tekniska tillämpningar och

medier för att uppfylla detta, men vi anser att det bästa vore ett skrivskyddat medium som helt saknar fysisk kontakt med infrastrukturen. Vidare anser vi att 3-2-1-metoden är ett bra ramverk, där en kopia lagras offline medan två andra kan lagras i molnet eller inom infrastrukturen (på två olika medium) för snabb åtkomst. Detta tror vi ökar effektiviteten om man snabbt behöver kunna skriva till eller återställa från en sådan mindre kritisk molnversion. För att säkerställa att man har tillräcklig kapacitet anser vi att man behöver ha god koll på sin hårdvara, annars riskerar man att behöva radera det infekterade systemet för att återställa en backup-version. Detta skulle emellertid skapa problem, då det infekterade systemet även fortsättningsvis kommer att vara av hög betydelse för att kunna utföra forensik och sedermera informera organisationens intressenter om vad och hur intrånget skett. Den forensiska utredningen är en förutsättning för att kunna säkerställa när den senaste backupen gjordes innan infektionen ägde rum, så att en eventuell dropper inte riskerar återställas rakt in i det återskapade nya systemet. I backup-rutiner anser vi även att patch management ingår i den grad att man direkt behöver säkerställa att återskapad mjukvara är patchad och inte riskerar att undgås, då har man teoretiskt initierat nya attackvektorer och står återigen oskyddad.

5.7. Konstant övervakning

Både i litteratur- och intervjustudien framgår det tydligt att man behöver ha ett bra sätt att övervaka sitt nätverk på. Detta eftersom att om man inte vet vad som sker eller vad som har skett, så kan man heller inte agera. Både Shekhtman och Waisbard (2021) och respondenterna talar mycket om att ha fullständiga loggar över vad som sker i nätverket, och att dessa framförallt måste vara tillgängliga under en lång tid då ransomwareangrepp kan tänkas fortgå under en tämligen lång tid. Vidare menar både Miloslavskaya (2018) och respondenterna att det är vedertaget att tillämpa en SOC-verksamhet om nätverket är stort eller i övrigt känsligt för intrång. Miloslavskaya (2018) talar generellt mer positivt om automatiska verktyg, medan respondenterna menar att det inte kommer att gå att bygga bättre automatiserade detekteringsverktyg givet dagens teknologi annat än att ha mänsklig konstant övervakning. Även brandväggar lyfts fram, där litteraturen lägger en stor vikt vid dem medan respondenterna snarare talar om dem som rena hygienfaktorer och menar att de kan vara otroligt svåra att konfigurera för att faktiskt utgöra ett adekvat skalskydd.

Det är uppenbart att konstant övervakning är nyckeln till korrekt respons mot dataintrång, däremot får inte den mänskliga faktorn bortses från. Det som skiljer litteraturen med det som respondenterna säger är att det är viktigare att man har en mänsklig expert som kan se när något sker än vad det är att ha automatiska verktyg för detta. I vår mening kan automatiska verktyg implementeras för att flagga för eventuella hot, däremot är en människa viktigare i dessa situationer då det alltid är denna som kommer fatta beslut om vad som behöver ske. En människa kommer automatiskt att vara mer snabbfotad och ständigt uppdatera sina signaturelement som den letar efter då nätverksövervakning sker. En till stor fördel med människor som övervakar IT-miljön är att den mänskliga övervakaren kan sålla bort falska flaggningar innan ärendet eskalerar till dyra konsulter. En automatisk övervakningstjänst introducerar teoretiskt nya attackvektorer, då den per se skulle få tämligen hög eller till och med överlägsen behörighet i nätverket. En mänsklig övervakare kommer dessutom att minska tiden från att hotet identifieras tills responsen initieras.

Vi håller särskilt med Richarz i hennes förklaring av att beställare sällan besitter korrekt kunskap inför upphandling av en övervakningsstjänst, samt att det blir problematiskt i frågan om offentlig upphandling då det avgörande beslutet kommer att fattas utefter prisbilden. Här anser vi att man särskilt behöver säkerställa goda rutiner och kunskap inför en upphandling, så att man faktiskt konkurrensutsätter marknaden på lika villkor och inte jämför vitt skilda tjänster emot varandra.

Vidare anser vi att korrekt konfigurerade brandväggar är viktigt i den grad att de utgör ett slags grovt filter för nätverksåtkomsten. Vi anser dock inte att detta skall användas som ett eget skydd, utan en brandvägg kan vara en sådan datapunkt att övervaka snarare än att förlita sig på som ensamt skydd. En enkel åtgärd gällande brandväggar är att blockera in- och utgående nätverkstrafik till geografiska platser där man vet att man vare sig har klienter eller personal. Däremot innebär detta en känsla av falsk trygghet då hotaktörer från den geografiska platsen kan använda sig av ett VPN för att se ut att vara på en annan plats än vad de faktiskt är på. Vidare vill vi lyfta fram ett citat från Hultgren *“Det spelar ingen roll hur höga murar man bygger eller hur djupa vallgravar man gräver, nature will find its way.”*. Detta tycker vi är en otroligt bra sammanfattning på hur man kan koppla cybersäkerhet till all form av säkerhet. Detta har vi inte minst sett tecken på i den stundande invasionen av Ukraina, där de påvisar att det är viktigare att kontinuerligt se vad som händer

än vad det är att ha rätt skydd på rätt ställe. Det är svårt att ställa alla sina stridsvagnar på gränsen.

5.8. Ransomware as a Service & ekonomisk affär

Både litteraturen och de intervjuade respondenterna är helt eniga i frågan om att det blivit allt enklare att som okunnig utföra cyberangrepp. Per Håkon Meland (2020) skriver i sin studie att olika delar av en sedvanlig ransomwareattack går att köpa på ljusskygga delar av internet, detta instämmer även respondenterna i, för försvinnande små summor. Respondenterna talar ändock mer om själva ekosystemet som skapat de senaste åren, där det nästan kan liknas vid att hotaktörer frilansar med varandra för att tillsammans skapa en värdekedja. Olika former av affiliates lyftes även fram av de intervjuade respondenterna, och det stärks upp i viss grad av den litteraturen som presenteras. Vad gäller den ekonomiska affären i ransomware som företeelse så tydliggörs detta genom intervjuerna med respondenterna. De är samstämmiga i att det ofta kan tänkas vara softisitikerade individer eller brottssyndikat, där den stora skillnaden mellan de kriminella och de goda är en vikande moral och etik. Samtliga respondenter, men även litteraturen från Per Håkon Meland (2020), står starkt fast vid att den drivande faktorn hos hotaktörerna är den ekonomiska vinningen. Richarz påpekar tydligt att så länge vi fortsätter den digitalisering som sker, där allt mer data skapas eller skickas, desto större kommer marknaden för cyberkriminella att bli, detta är ingenting som presenteras explicit från övriga respondenter. Vidare har respondenterna gett oss en större aktuell insyn i varifrån (geografiskt) hoten kommer från.

Vår uppfattning vad gäller det förändrade ekosystemet inom cyberbrottslighet är att för att organisationer skall kunna motstå denna form av hot från hela brottsnätverket så behöver även organisationerna samverka i en annan grad. Detta kan t. ex ske genom att de anställda får bättre kännedom i vad exempelvis ett phishing-mail är, kontohantering och hur man generellt vidtar goda hygienrutiner inom ett nätverk. Vi anser precis som respondenterna att för att upptäcka varifrån hoten kommer, samt vad nästa steg blir, så behöver man följa pengarna. Det är i slutet av dagen en kommersialiserad affär som uppstått, och det är nästan uteslutande ekonomiska initiativ som driver hotaktörerna. Vidare anser vi att fortsatta politiska påtryckningar bör ske, så att svaga stater slutar se mellan fingrarna vad gäller

cyberbrottslighet. Allt annat lika är den enda lösningen på en ökad cyberkriminalitet att begränsa den ekonomiska vinningen i detta affärsupplägg.

Vi håller med Richarz i hennes uppfattning om att ju större den digitala världen blir, desto större blir spelplanen för de cyberkriminella, allt annat lika.

Vidare håller vi med om att transparensen bör öka vid dataintrång, då detta troligtvis kommer öka medvetenheten och diskussionen kring cybersäkerhet. Vi ser stigmat och den generande faktorn sakteligen gå åt rätt håll, där det blir allt mer accepterat att tala öppet om dessa risker. Detta särskilt efter den stora incident som utsatte en betydande livsmedelskedja i Sverige och som lärde hela dess befolkning om riskerna kring cyberhot och hur sårbart ett samhälle kan vara som bygger på stora digitaliserade funktioner.

6. Slutsats & rekommendationer

Det är uppenbart att organisationer är sårbara mot cyberhot, inte minst ransomwareattacker. Medvetenheten ökar konstant som en produkt av att fler publikationer offentliggörs på attacker som genomförts, där även systemviktiga attacker sprider en rädsla och känsla för sårbarhet hos individer och organisationer. Det förekommer alltför ofta att man prioriterar fel eller saknar tillräckligt god kunskap inom området för att skydda sig på ett adekvat vis. Det förefaller även uppenbart att alltför många organisationer fallerar i sitt säkerhetsarbete på ett grundläggande och fundamentalt plan. Genom arbetets gång står det klart att bristerna oftast tycks förekomma i rutinerna snarare än etableringen av tillämpningarna.

6.1. Akademiskt bidrag

Tanken med denna studie har varit att lägga en vetenskaplig grund för hur området varit fram till och med publiceringen av rapporten. Branschens förutsättningar har snabbt och ständigt förändrats under arbetets förfarande, varför rapporten heller inte skall ses som en nutidsbild vid läsandets stund, utan lägger grunden för fortsatta studier.

Genom arbetet publicerar vi hittills ofunnet material kring Ransomware 3.0, varför vi anser att en större akademisk grund skall genomföras för denna metod. Inriktningar inom detta område bör ligga på hur implementering av incidentrespons skall ske, samt hur organisationer kan utveckla sina förmågor till försvar.

Vi anser att alla akademiska studier inom området kommer att ligga efter händelseutvecklingen vid publikation. Branschen, hoten och åtgärderna förändras konstant. Det som tagits upp i detta arbete visar mindre på hur det tekniska fungerar, utan mer hur det fungerar på en organisatorisk nivå. Detta tror vi inte är något som kommer att ändras. Organisationer kommer att fortsätta använda backup:s, de kommer behöva testa att de fungerar och de kommer att behöva övervaka sin infrastruktur för att på ett adekvat sätt hålla koll på vad som sker, när det sker oavsett vilken typ av hot det är. Det är ändock viktigt att man fortsätter studera de specifika attackerna som sker, för att sprida kunskap och medvetenhet om de riskbilder som finns.

Vår uppfattning är att det behövs ännu mer forskning inom hård- och mjukvaruskydd, däremot anser vi att de rutiner och beredskapsplaner som idag bör användas av samtliga organisationer tillgodoser de säkerhetskrav som ställs av branschen.

6.2. Rekommendationer till organisationer

För att ta bort den ekonomiska vinningen bör rekommendationerna till organisationer vara att inte tänka på att betala lösesumman. Det saknas evidensbaserade grunder till att betala och helt återfå tillgång till sin data, utan att bli utpressad på nytt. Så länge det finns organisationer som betalar lösesumma kommer ransomware att fortsätta existera.

Under den senaste tiden har organisationer blivit mer medvetna om vikten av IT-säkerhet, däremot existerar det fortfarande fall där organisationer ser IT-säkerhet som en ren kostnadsfråga. Som organisation behöver man först och främst inse att IT-säkerhet är något viktigare än bara en ren kostnad, även om konsekvenserna av att inte investera i detta är högst hypotetiska, samt att de påverkar mer än bara IT-funktionen hos organisationen. Hur man hanterar organisationens data behöver vara en av de viktigaste frågorna för varje organisation. Rent tekniskt finns en del faktorer som varje organisation bör se till att uppfylla för att minska risken för att bli utsatt. De viktigaste preventiva åtgärderna handlar om att alltid vara fullständigt patchad, hantera sitt data krypterat, ha väl fungerande backup-rutiner med beprövade återskapningsmetoder. Ytterligare åtgärder som skall beaktas är god kännedom om sin mjuk-/hårdvara och tillhörande användarkonton, övervaka sitt nätverk samt ha goda protokoll såsom brandväggar och loggar. Förslagsvis bör en organisation ta hjälp av sakkunniga inom området. Den mest omfattande tjänsten som samtidigt tillgodoser många av de åtgärder man som organisation behöver tänka på är en SOC-verksamhet. Detta investerar man förslagsvis i, oavsett om den är outsourcad eller drivs i egen regi. En SOC förblir då ens säkerhet att undgå en fullständig kryptering och kan hjälpa att undgå betalning av lösesumma.

Det är klart och tydligt att det som driver hotaktörerna är den ekonomiska vinningen som är hänförlig till ransomwareangrepp. Uppkomsten av det ekosystem som idag finns gör det ännu lättare för gemene man att angripa en organisation och utpressa denna på pengar. Det har även blivit lättare för dessa hotaktörer att ta emot lösesumma via kryptovaluta, där deras transaktioner förblir anonyma utan vedertagen ekonomisk insyn. Uppkomsten av dessa brottssyndikat kräver i någon grad att hotaktörerna besitter tvivelaktig etik och moral, samt

att de verkar i en stat med svagt styre där man har lätt att se mellan fingrarna och inte står redo att lagföra hotaktörerna eller motverka dessa brottssyndikat.

Referenslista

Alieksieieva, K. och Dmytruk, V. (2017) 'IMPROVEMENT OF THE EFFECTIVENESS OF INFORMATION SECURITY MANAGEMENT USING INTELLIGENT TECHNOLOGIES', Scientific and Practical Cyber Security Journal, (1(1)), pp. 23–26. Tillgänglig på: https://journal.scsa.ge/papers/improvement-of-the-effectiveness-of-information-security-management-using-intelligent-technologies-2/. [Hämtad 4/2-23]

Företagsekonomiska forskningsmetoder av Alan Bryman, Emma Bell (Häftad) (2017) *Bokus.com*. Tillgänglig på: https://www.bokus.com/bok/9789147112074/foretagsekonomiska-forskningsmetoder/ [Hämtad 31/5-23].

Chappell, B. (2013) 'Privilege management – the industry's best kept secret', Network Security, 2013(10), pp. 12–14. Tillgänglig på: https://doi.org/10.1016/S1353-4858(13)70114-4. [Hämtad 2/5-23]

Chen, T.M. och Abu-Nimeh, S. (2011) 'Lessons from Stuxnet', *Computer*, 44(4), pp. 91–93. Tillgänglig på: https://doi.org/10.1109/MC.2011.115. [Hämtad 4/2-23]

Cloudflare (2023) What is encryption? | Types of encryption, Cloudflare. Tillgänglig på: https://www.cloudflare.com/learning/ssl/what-is-encryption/ [Hämtad 9/5-23].

Cluley, G. (2021) *Average ransomware payouts shoot up 171% to over $300,000 | Tripwire*. Tillgänglig på: https://www.tripwire.com/state-of-security/average-ransomware-payouts-shoot-up [Hämtad 6/3-23].

Croke, L. (2020) 'Protecting your organization from e-mail phishing and ransomware attacks', AORN Journal, 112(4), pp. P10–P12. Tillgänglig på: https://doi.org/10.1002/aorn.13229. [Hämtad 6/3-23]

Computing and Electronic Commerce, 31(4), pp. 320–342. Tillgänglig på: https://doi.org/10.1080/10919392.2022.2028530. [Hämtad 2/5-23]

Counter Threat Unit Research Team (2017) WCry (WannaCry) Ransomware Analysis. Tillgänglig på: https://www.secureworks.com/research/wcry-ransomware-analysis. [Hämtad 8/5-23]

Didriksson Fröjd, S. (2022) *Dataskyddet och Chat Control : Om obligatorisk spårning av interpersonell kommunikation i syfte att motverka och bekämpa barnpornografi och grooming på nätet*. Tillgänglig på: https://urn.kb.se/resolve?urn=urn:nbn:se:su:diva-214975 [Hämtad 8/5-23]

Enoch, S.Y. et al. (2020) 'HARMer: Cyber-Attacks Automation and Evaluation', IEEE Access, 8, pp. 129397–129414. Tillgänglig på: https://doi.org/10.1109/ACCESS.2020.3009748. [Hämtad 2/5-23]

EU. What is GDPR, the EU's new data protection law? (2018) GDPR.eu. Tillgänglig på: https://gdpr.eu/what-is-gdpr/. [Hämtad 8/5-23]

Europol (2023) Internet Organised Crime Threat Assessment (IOCTA) 2019, Europol. Tillgänglig på: https://www.europol.europa.eu/publications-events/main-reports/internet-organised-crime-threat-assessment-iocta-2019 (Hämtad 9/5-23).

Furnell, S. och Emm, D. (2017) 'The ABC of ransomware protection', Computer Fraud & Security, 2017(10), pp. 5–11. Tillgängling på: https://doi.org/10.1016/S1361-3723(17)30089-1. [Hämtad 27/2-23]

Grimes, R. (2021) Ransomware Protection Playbook. Wiley. Tillgänglig på: https://learning.oreilly.com/library/view/ransomware-protection-playbook/9781119849124/ [Hämtad 20/3-23].

Häckel, B. et al. (2019) 'Assessing IT availability risks in smart factory networks', Business Research, 12(2), pp. 523–558. Tillgänglig på: https://doi.org/10.1007/s40685-018-0071-5. [Hämtad 2/5-23]

ISO (2023) ISO/IEC 27001 Standard – Information Security Management Systems, ISO. Tillgänglig på: https://www.iso.org/standard/27001 [Hämtad 9/5-23].

IT Governance (2023) ISO 27001. Tillgänglig på: https://itgovernance.co.uk/iso27001 [Hämtad: 9 May 2023].

Kee, Y. *et al.* (2017) ‘Quantitative Susceptibility Mapping (QSM) Algorithms: Mathematical Rationale and Computational Implementations’, *IEEE Transactions on Biomedical Engineering*, 64(11), pp. 2531–2545. Tillgänglig på https://doi.org/10.1109/TBME.2017.2749298 [Hämtad 31/5-23].

Li, Z. och Liao, Q. (2020) ‘Ransomware 2.0: to sell, or not to sell a game-theoretical model of data-selling Ransomware’, in Proceedings of the 15th International Conference on Availability, Reliability and Security. New York, NY, USA: Association for Computing Machinery (ARES ’20), pp. 1–9. Tillgänglig på: https://doi.org/10.1145/3407023.3409196. [Hämtad 17/3-23]

Maiorca, D., Biggio, B. och Giacinto, G. (2020) ‘Towards Adversarial Malware Detection: Lessons Learned from PDF-based Attacks’, *ACM Computing Surveys*, 52(4), pp. 1–36. Tillgänglig på: https://doi.org/10.1145/3332184. [Hämtad 4/2-23]

Malecki, F. (2019) ‘Best practices for preventing and recovering from a ransomware attack’, Computer Fraud & Security, 2019(3), pp. 8–10. Tillgänglig på: https://doi.org/10.1016/S1361-3723(19)30028-4. [Hämtad 17/3-23]

Meland, P.H., Bayoumy, Y.F.F. and Sindre, G. (2020) ‘The Ransomware-as-a-Service economy within the darknet’, Computers & Security, 92, p. 101762. Tillgänglig på: https://doi.org/10.1016/j.cose.2020.101762. [Hämtad 9/5-23]

Miloslavskaya, N. (2018) ‘Network Security Intelligence Center as a combination of SIC and NOC’, Procedia Computer Science, 145, pp. 354–358. Tillgänglig på: https://doi.org/10.1016/j.procs.2018.11.084. [Hämtad 2/5-23]

Min, D. et al. (2022) ‘A Content-Based Ransomware Detection and Backup Solid-State Drive for Ransomware Defense’, IEEE Transactions on Computer-Aided Design of Integrated Circuits and Systems, 41(7), pp. 2038–2051. Tillgänglig på: https://doi.org/10.1109/TCAD.2021.3099084. [Hämtad 9/2-23]

Murali, R. och Shunmuga Velayutham, C. (2020) ‘A preliminary investigation into automatically evolving computer viruses using evolutionary algorithms’, *Journal of*

Intelligent & Fuzzy Systems, 38(5), pp. 6517–6526. Tillgänglig på: https://doi.org/10.3233/JIFS-179732. [Hämtad 4/2-23]

Nakov, S. (2023) Encryption: Symmetric and Asymmetric. Tillgänglig på: https://cryptobook.nakov.com/encryption-symmetric-and-asymmetric. [Hämtad 2/5-23]

NCSC (2022) 'Cybersäkerhet i Sverige 2022 Del 2: Rekommenderade säkerhetsåtgärder'. [Hämtad 2/5-23]

Palanisamy, R., Norman, A.A. och Mat Kiah, L. (2021) 'BYOD Security Risks and Mitigation Strategies: Insights from IT Security Experts', Journal of Organizational

Ransomware: What It Is & What To Do About It, Certified Information Systems Auditor. [Hämtad 9/2-23]

Ross, R., Winstead, M. och McEvilley, M. (2022) Engineering Trustworthy Secure Systems. NIST SP 800-160v1r1. Gaithersburg, MD: National Institute of Standards and Technology, p. NIST SP 800-160v1r1. Tillgänglig på: https://doi.org/10.6028/NIST.SP.800-160v1r1. [Hämtad 21/3-23]

Shekhtman, L. och Waisbard, E. (2021) 'EngraveChain: A Blockchain-Based Tamper-Proof Distributed Log System', Future Internet, 13(6), p. 143. Tillgänglig på: https://doi.org/10.3390/fi13060143. [Hämtad 2/5-23]

Sletten, B. (2016) 'Encyption' O'Reilly Media, Inc. Tillgänglig på: https://learning.oreilly.com/videos/encryption/9781491944363/ [Hämtad 31/5-23]

Statista (2023) Total data volume worldwide 2010-2025, Statista. Tillgänglig på:: https://www.statista.com/statistics/871513/worldwide-data-created/. [Hämtad 9/5-23]

Thomas, J. och Galligher, G. (2018) 'Improving Backup System Evaluations in Information Security Risk Assessments to Combat Ransomware'. Rochester, NY. Tillgänglig på: https://papers.ssrn.com/abstract=3095629 [Hämtad 17/3-23].

Truesec (2023) *Threat Intelligence Report 2023: Cybersecurity Priorities*, *Truesec*. Tillgängli på: https://www.truesec.com/hub/report/threat-intelligence-report-2023 (Hämtad 9/5-23).

UK NCSC (2023) ‘Mitigating malware and ransomware attacks’. Tillgänglig på: https://www.ncsc.gov.uk/guidance/mitigating-malware-and-ransomware-attacks. [Hämtad 8/5-23]

Vadhan, S. ‘Computational Complexity’. *Harvard University*. Tillgänglig på: https://people.seas.harvard.edu/~salil/research/ComputationalComplexity-2ndEd.pdf. [Hämtad 9/5-23]

Warmke, C. (2021) ‘What is bitcoin?’, *Inquiry*, 0(0), pp. 1–43. Tillgänglig på: https://doi.org/10.1080/0020174X.2020.1860123. [Hämtad 2/5-23]

Werlinger, R. et al. (2010) ‘Preparation, detection, and analysis: the diagnostic work of IT security incident response’, Information Management & Computer Security. Edited by S. M. Furnell och N. Clarke, 18(1), pp. 26–42. Tillgänglig på: https://doi.org/10.1108/09685221011035241. [Hämtad 2/5-23]

Yacoob, I. et al. (2017) ‘The rise of ransomware and emerging security challenges in the Internet of Things’, Elsevier B.V [Preprint]. Tillgänglig på: https://www-sciencedirect-com.focus.lib.kth.se/science/article/pii/S1389128617303468 [Hämtad 9/2-23].

Bilagor

Bilaga 1. Intervjuguide

Innan intervjun börjar:

- Är det okej att vi spelar in denna intervju (endast ljud)?
- Vill du vara anonym eller kan vi nämna organisationens/ditt namn i vårt arbete?

Intervjuguide:

1. Vilka är vi? Varför gör vi detta? Vad vill vi få ut av intervjuerna?
    a. Nick Derek och Christoffer Ericson.
    b. Studenter vid Kungl. Tekniska Högskolan, Maskinteknik.
    c. Skriver kandidatexamensarbete om IT-säkerhet, framförallt utvecklingen av denna - med fokus på ransomwareattacker mot organisationer.
    d. Har ett intresse för detta, men saknar relevant bakgrund.
2. Vem är du?
    a. Din koppling till IT-säkerhet? Ett intresse hela livet?
    b. Utbildning/karriär?
    c. Vad innebär din roll hos organisationen?
    d. Har din roll förändrats under din tid inom organisationen?
3. Organisationen/branschen:
    a. Vad är organisationens huvudsakliga arbete?
    b. Hur ser kunderna ut? Stora eller små? Samhällsviktiga?
    c. Har ni hanterat/blivit utsatta för ett ransomwareangrepp?
    d. OM TIDIGARE “NEJ” Har ni blivit utsatta för ett IT-angrepp?
4. Produktutveckling:
    a. Hur ser du på produktutveckling inom branschen? Går den snabbt? Hinner du förstå allt som sker?
    b. Vad är din generella uppfattning om ransomware utveckling? Ökande problematik? Stort hot?
    c. Malware i allmänhet?
    d. Hur jobbar ni inom organisationen för att hela tiden följa marknaden?
    e. Upplever du att området och metoderna inom produktutveckling har förändrats under din tid i organisationen? Under din tid i branschen?

f. Vad eller vem anser du skapar drivkrafterna inom branschen för produktutveckling? Är produkterna ett svar på angriparens attack, eller är säkra system föremål för angriparens drivkraft att anta en utmaning?

5. Incidentrespons:
    a. Kan du nämna några av era viktigaste funktioner och processer?
    b. Hur säkerställer ni att era viktigaste funktioner och processer fortfarande är aktiva?
    c. Hur skyddar ni er mot IT-angrepp?
    d. Hur upptäcker ni ett IT-angrepp?
    e. Vad är det första ni gör vid ett angrepp?
    f. Har ni en responsplan för hur ni ska agera vid ett angrepp? Är denna beprövad?
    g. Använder ni någon managerad tjänst, d.v.s. outsourcad IT-säkerhetstjänst?
    h. Hur behandlar ni ett angrepp efter det att det är avvärjt?
    i. Uppdateras protokoll efter ett IT-angrepp?
    j. Rutiner för att informera intressenter? Lyder ni under lagstadgad marknadskommunikation där ni måste offentliggöra kritiska händelser?
    a. Har er responsplan sett likadan ut? Hur länge?
6. Riskhantering:
    a. Vad är din uppfattning gällande det bästa skyddet emot ransomware?
    b. Använder ni någon form av multi-faktor-autentisering?
    c. Hur övervakar/monitorerar ni nätverket/-trafiken?
    d. Hur upprätthåller ni ert protokoll kring användning av uppkopplade enheter? Fortbildning av personal?
    e. Hur genomför ni en sökning av eventuella sårbarheter i ert nätverk?
    f. Hur inventeras stacken, samt de tillhörande kontona? Vem ansvarar? SYSADMIN?
7. Backup:
    a. Anser du att backup är ett bra skydd mot ransomware?
    b. Använder ni backups?
    c. Vilken form av backup använder ni? Kontinuerlig eller snapshots?
    d. OM SNAPSHOTS: Hur ofta tas backups?
    e. Vart lagras dessa? Online/offline?

f. Har ni protokoll för automatiska back up:s över hela infran? Egen funktionsgrupp som är ansvarig inom organisationen?
g. Har ni provat om back up-rutinerna faktiskt fungerar i händelse av en attack då de faktiskt behövs?
h. Genomför ni en säkerhetskontroll på era backups?

8. Kryptering
    i. **Den teoretiska studie vi gjort visar att data inom en organisations nätverk bör krypteras både då den kommuniceras samt lagras på en end-point. Kryptering är även en ransomware-angripes viktigaste verktyg för att kunna utkräva lösensumman. Vi söker nu svar från verkligheten annat än teorin:**
    b. Hur/var lagrar ni data? Sker detta lokalt eller i externa (cloud)tjänster?
    c. Krypterar ni endast kommunikation eller tillämpas kryptering på data in rest?
    d. Hur implementeras nyckelhanteringen? Lagras nycklar i eller utanför systemet?
    e. Sker hybridkryptering eller använder ni endast en krypteringsmetod/-algo?
9. Efterkommande frågor:
    a. Hur tror du att utvecklingen av skydd och respons mot ransomware kommer fortlöpa?
    b. För din och vår skull, ta gärna en minut och fundera igenom om det finns något du har sagt som du inte vill att vi ska nämna/stryka? Finns det något du känner att du **inte** talat om som du gärna skulle lyft fram?
    c. Finns det något vi inte tagit upp som du anser är en viktig del inom skydd och respons mot ransomware?
10. Tacka!

Bilaga 2. Ändringsmanus

Detta är de ändringar vi har gjort utifrån opponering från två andra kurskamrater samt handledare.

Ändringsmanus
Grupp: 10

Sidnummer	**Kommentar/ Förslag från**	**Kortfattat kring förslag/kommentar**	**Åtgärdat**		**Kommentar/Motivering**
			JA	**NEJ**	

Sammanfattning	Alma J, Simon L, Gunilla ÖS	Lägg in syfte och tillvägagångssätt i sammanfattningen	X		En uppenbarhet att detta skall vara med i sammanfattning, lagt till.
Sammanfattning	Alma J	“patch management” inte än introducerat, kort förklaring om vad det är	X		Kort beskrivning tillagd, en längre beskrivning kommer senare i arbetet.
Genomgående	Alma J	Kolla över hur förkortnignar görs(p.g.a., p g a)	X		Dubbelkollat med ordbok vad som är korrekt förkortning och ändrat alla till dessa.
Genomgående	Alma J	Begrepp som inte är introducerade används utan förklaring.		X	Vi anser att den förklaring som finns att tillhandahålla är tillräcklig.
1-2, 4-19	Gunilla ÖS	Kolla över referering, efter första meningen	X		Refererat på fel sätt, ändrat så det är korrekt.
20	Gunilla ÖS	Behöver vetenskaplig forskningsmetodik för att motiver och stärka tillvägagångsätt	X		Var ovetande om att detta krävdes, lagt till.
26, 32, 35-36	Alma J	Oklarheter angående vem som sagt vad i inledande stycke för teman	X		Ändrat så det är tydligt att denna information kommer från respondenter.
44-54	Simon L	Användning av “vi anser/håller med” mer sparsam		X	Vi anser att på det sättet analys och diskussion är upplagd är det viktigt att göra det tydligt vad som är vår uppfattning och vad som är respondenternas uppfattning.

TRITA – ITM-EX 2023:123